
Mariana BS - Cybersecurity Engineer
GUIA COMPLETO DE ESTUDOS
Analista SOC N1
LOG TAMBÉM CONTA HISTÓRIA
Anatomia de um Log
Oct 24 10:15:23 host01 sshd[4625]: Failed password for admin from 192.168.1.66 port 52214 ssh2
Data/Hora
Host
Processo[PID]
Evento
Usuário
IP
Porta
Protocolo
Tempo e Linha do Tempo
UTC e fusos horários
Epoch (timestamp)
Clock drift
Atraso de ingestão
Impacto na correlação
Formatos e Normalização
Syslog
JSON
CEF
LEEF
Log bruto
Normalização
Correlação
Correlação de Eventos
Relacionar eventos
Reconstruir ações
Identificar a cadeia
Confirmar hipótese
Qualidade do Log
Completude
Consistência
Padronização
Retenção
Valor investigativo
Fontes de Log (exemplos)
Windows
Linux
Firewall
E-mail
Proxy
VPN
AD
Nuvem
EDR
SIEM
SOC N1
SEM CONTEXTO É SÓ TEXTO ALEATÓRIO
ANATOMIA DO EVENTO
TEMPO E FUSO HORÁRIO
FORMATOS E NORMALIZAÇÃO
CORRELAÇÃO DE LOGS
QUALIDADE DO LOG
TIMELINE DE INCIDENTE
LABORATÓRIOS
LOG É EVIDÊNCIA
SOC N1
Plano de Estudo – Módulo 5
Entender a estrutura do log
Trabalhar tempo e fusos
Normalizar e correlacionar
Analisar 10 fontes de log
Praticar em 7 laboratórios
Montar uma timeline completa
LINHA DO TEMPO NÃO MENTE
Módulo 5 — Logs
Campos, horários, formatos, normalização e correlação:
como transformar linhas de texto em uma história verificável.
Neste volume:
Anatomia de um evento.
Tempo (UTC, fusos, epoch, clock drift, atraso de ingestão).
Formatos e normalização.
Logs comentados de dez fontes.
Correlação temporal.
Qualidade do log.
Montagem de timeline.
Laboratórios:
Sete, do campo isolado à timeline completa.
Três cenários com arquivos fictícios:
Timeline com drift.
Phishing do e-mail ao endpoint.
Qualidade de log.
Arquivos no documento e também no anexo Lab_Modulo05_logs.zip.
Pré-requisitos: Módulos 0 a 4.

Sumário

Módulo 5: Logs 4
5.1 Objetivo 4
5.2 O que é um log e por que ele é a matéria-prima do SOC 4
5.3 Anatomia de um evento 5
Como cada fonte chama os mesmos campos 6
5.4 Tempo: o campo que mais engana 7
UTC, horário local e ISO 8601 7
Fusos que você vai encontrar 8
Os três horários de um evento 9
Clock drift e NTP 9
5.5 Formatos e normalização 10
Normalização 11
Do bruto ao enriquecido 11
5.6 Logs comentados, fonte por fonte 12
Windows (Security 4624) 12
Linux (sshd em /var/log/auth.log) 13
Firewall (key=value) 14
Proxy (JSON, um evento por linha) 14
DNS (resolver, JSON) 15
VPN 15
EDR (evento de processo, JSON) 16
WAF (JSON) 16
E-mail (rastreamento de mensagens) 17
Active Directory (4740 e 4728) 17
Windows (Security 4625: falha de logon) 18
Linux (sudo) 19
DHCP (Windows Server) 19
Nuvem: sign-in do Entra ID 20
5.7 Correlação temporal: montando a timeline 21
5.8 Qualidade do log: quando a evidência mente sem querer 22
5.9 Qual log responde a cada pergunta? 23
5.10 Como citar logs no ticket 24
5.11 Como isso aparece no SOC: três mini-casos 24
Caso 1: "O horário do alerta não bate" 24
Caso 2: "Busquei o IP e não achei nada" 24
Caso 3: "Dois acessos idênticos no mesmo milissegundo" 24
5.12 Comandos para ler logs 25
5.13 Ferramentas 25

Fechamento do Módulo 5 26
Laboratórios 26
Lab 5.1: Anatomia na sua máquina 26
Lab 5.2: Tempo 27
Lab 5.3: Normalização no papel 27
Lab 5.4: Timeline com fusos, drift e duplicata 28
Lab 5.5: O mesmo caso pela linha de comando 31
Lab 5.6: Do e-mail ao endpoint 32
Lab 5.7: Quando o log mente sem querer 34
Erros comuns 36
Falsos positivos comuns ligados a logs 36
Exercícios 37
Perguntas de entrevista 38
Checklist de domínio 41
Resumo do módulo 41
Cheat sheet de logs 41
Respostas comentadas dos exercícios 42
Gabaritos dos laboratórios 43
Lab 5.2 43
Lab 5.3 44
Lab 5.4 44
Lab 5.5: saídas esperadas 45
Lab 5.6 46
Lab 5.7 47
Próximo módulo 47

Módulo 5: Logs

5.1 Objetivo

Nos módulos anteriores, logs apareceram em todo canto: firewall, DNS, DHCP, VPN, Windows, Linux. Agora eles são o assunto principal. Um N1 passa a maior parte do turno lendo eventos, e a diferença entre uma triagem boa e uma ruim quase sempre está num campo mal lido ou num horário mal convertido. Ao final deste módulo você deve conseguir:

- Identificar e interpretar os campos essenciais de um evento: timestamp, fuso, hostname, usuário, IPs, portas, ação, Event ID, processo, processo pai, hash, URL, domínio, user-agent e session ID.
- Converter horários entre UTC, horário local e epoch, e reconhecer clock drift, atraso de ingestão e logs sem fuso.
- Reconhecer os formatos mais comuns (syslog, CEF, key=value, JSON, CSV, XML/EVTX) e entender o que é normalização.
- Ler logs de Windows, Linux, firewall, proxy, DNS, VPN, EDR, WAF, e-mail e Active Directory.
- Correlacionar eventos de fontes diferentes usando chaves de pivô e montar uma timeline defensável.
- Desconfiar com método: lacunas, duplicatas, parsers quebrados e retenção.

5.2 O que é um log e por que ele é a matéria-prima do SOC

Log é o registro escrito de que algo aconteceu: um login, uma conexão, um processo, uma consulta DNS, um e-mail entregue. Cada registro individual é um **evento** (Módulo 0). O SOC não vê o ataque acontecendo; ele vê **os registros que o ataque deixou**, quando esses registros existem, chegam e são entendidos.

Termo	O que é	Exemplo
Evento	Uma ocorrência registrada por uma fonte.	Windows registrou o Event ID 4624 às 13:02:11 UTC.
Log	O conjunto de eventos de uma fonte, em arquivo, canal ou fluxo.	O canal Security do SRV-FILE01; o arquivo /var/log/auth.log.
Telemetria	Fluxo contínuo de eventos enviados para análise.	O agente do EDR enviando processos e conexões para o console.
Alerta	Notificação gerada quando eventos casam com uma regra.	"Mais de 20 falhas de login em 5 minutos."
Evidência	Evento (ou conjunto) que sustenta uma conclusão, identificado e preservado.	O 4624 tipo 10 com Logon ID 0x5A3F21, citado no ticket com a consulta usada.

> 🎯 **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Três atitudes que este módulo vai treinar:
>
> - **Ler o campo, não o resumo.** O título do alerta é a opinião da regra; o campo é o fato.
> - **Converter o horário antes de comparar.** Duas fontes em fusos diferentes contam histórias diferentes até você normalizar.

- **Separar "não aconteceu" de "não foi registrado".** Ausência de log é lacuna até que se prove o contrário.

NA VIDA REAL

No curso: "Todo evento relevante é registrado."

Na vida real: o evento relevante foi registrado, num servidor sem agente, com o relógio adiantado, num formato que o parser não entende, e a retenção local era de 2 dias.

O evento existiu. A evidência, nem tanto.

5.3 Anatomia de um evento

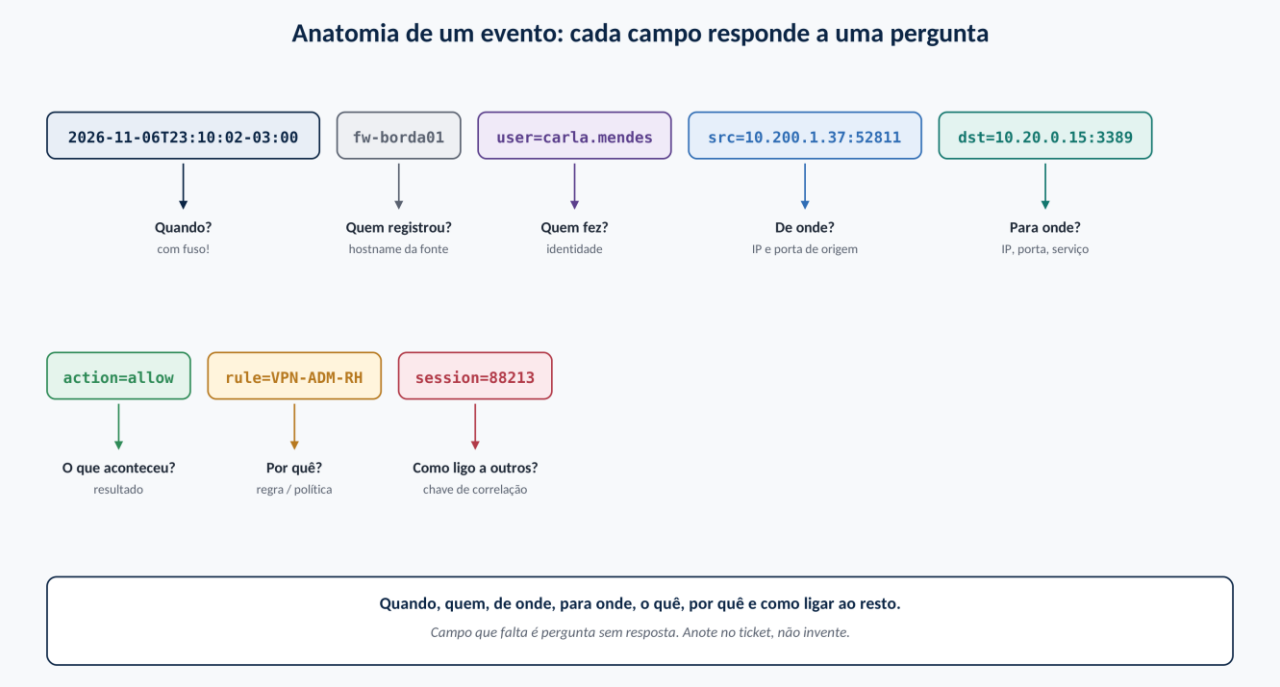


Figura 5.1: Cada campo de um evento responde a uma pergunta de investigação

Fontes diferentes dão nomes diferentes aos campos, mas as perguntas são sempre as mesmas. A tabela abaixo é a sua referência de bolso: o que cada campo significa, onde ele engana e que pergunta ele responde.

Campo	O que é	Armadilha comum	Pergunta que responde
timestamp	Momento do evento, segundo a fonte.	Pode ser hora de ingestão, e não do evento; pode estar sem fuso.	Quando?
timezone	Fuso do timestamp (Z, -03:00, +00:00).	Ausente em syslog tradicional; console exibindo em outro fuso.	Em qual referência de tempo?
hostname	Nome da máquina que gerou o evento.	Nome curto x FQDN; hostname do coletor no lugar da fonte; nomes reaproveitados.	Onde aconteceu?

Campo	O que é	Armadilha comum	Pergunta que responde
username	Conta envolvida.	Formatos diferentes (CORP\ana, ana@empresa, ana); conta de máquina (termina em $); "SYSTEM".	Quem?
source IP	Endereço de quem iniciou.	NAT, proxy, load balancer e VPN trocam o IP (Módulos 1 e 2).	De onde?
destination IP	Endereço do alvo.	IP de CDN ou nuvem compartilhado por milhares de sites.	Para onde?
source port	Porta de origem, normalmente efêmera.	Confundir com serviço; é essencial para casar com NAT.	Qual conexão exatamente?
destination port	Porta do serviço.	Porta indica serviço esperado, não garante protocolo.	Qual serviço?
action	Resultado: allow, deny, block, success, failure.	allow não é "benigno"; block do WAF em modo detecção não bloqueia.	O que aconteceu?
event ID	Código do tipo de evento na fonte.	O mesmo número significa coisas diferentes em fontes diferentes.	Que tipo de evento é?
process	Executável envolvido (nome e caminho).	Nome pode imitar binário legítimo; caminho importa.	O que executou?
parent process	Processo que criou o processo.	Relação não prova intenção (Módulo 3).	Quem iniciou a execução?
hash	Impressão digital do arquivo (MD5, SHA-1, SHA-256).	Um byte diferente muda tudo; reputação limpa não é inocência.	Qual arquivo, exatamente?
URL	Endereço completo do recurso web.	Truncada no log; codificação (%20, %2F); só o domínio em HTTPS sem inspeção.	O que foi pedido?
domain	Nome resolvido ou acessado.	Subdomínio x domínio registrado; parecido não é igual.	Com quem falou pelo nome?
user-agent	Identificação do cliente HTTP.	Totalmente controlável pelo cliente; serve como pista, não prova.	Que programa fez a requisição?
session ID	Identificador da sessão (login, conexão, VPN, app).	Cada fonte tem o seu; não se cruzam sozinhos.	Como ligo este evento aos outros da mesma sessão?

> **DICA**
>
> Campo que costuma salvar investigações e que iniciantes ignoram: **o identificador de sessão** de cada fonte (Logon ID no Windows, PID e sessão no Linux, session ID na VPN, ProcessGuid no Sysmon, request ID no WAF). Ele permite dizer "todos esses eventos pertencem à mesma sessão", o que nenhuma coincidência de horário consegue provar.

Como cada fonte chama os mesmos campos

A mesma pergunta mora em lugares diferentes em cada fonte. Esta tabela é o "dicionário" para não se perder:

Pergunta	Windows Security	Linux (syslog)	Firewall (key=value)	Proxy (JSON)	EDR (JSON)	VPN
Quando?	SystemTime (UTC no XML)	início da linha (sem ano e fuso)	date + time + tz	time	timestamp	início da linha (Z)
Quem registrou?	Computer	hostname na linha	devname	nome do proxy (no coletor)	device	nome do gateway
Usuário	TargetUserName / SubjectUserName	"for USUÁRIO" na mensagem	user (se integrado ao AD)	user	user	user
Origem	IpAddress (Source Network Address)	"from IP" na mensagem	srcip	src	o próprio device	src_ip (público)
Destino	o próprio Computer	o próprio host	dstip	url / domínio	IP remoto do evento de rede	assigned_ip (interno)
Resultado	o Event ID (4624 x 4625)	Accepted / Failed	action	action + status	verdict / action	event
Sessão	TargetLogonId	PID entre colchetes	sessionid	raramente existe	ProcessGuid / process id	sessão / assigned_ip

5.4 Tempo: o campo que mais engana

Se você só puder dominar um assunto deste módulo, domine este. Investigação é sequência, e sequência depende de horário. Um erro de fuso transforma causa em consequência, coloca o usuário certo na hora errada e gera alertas que ninguém consegue reproduzir.

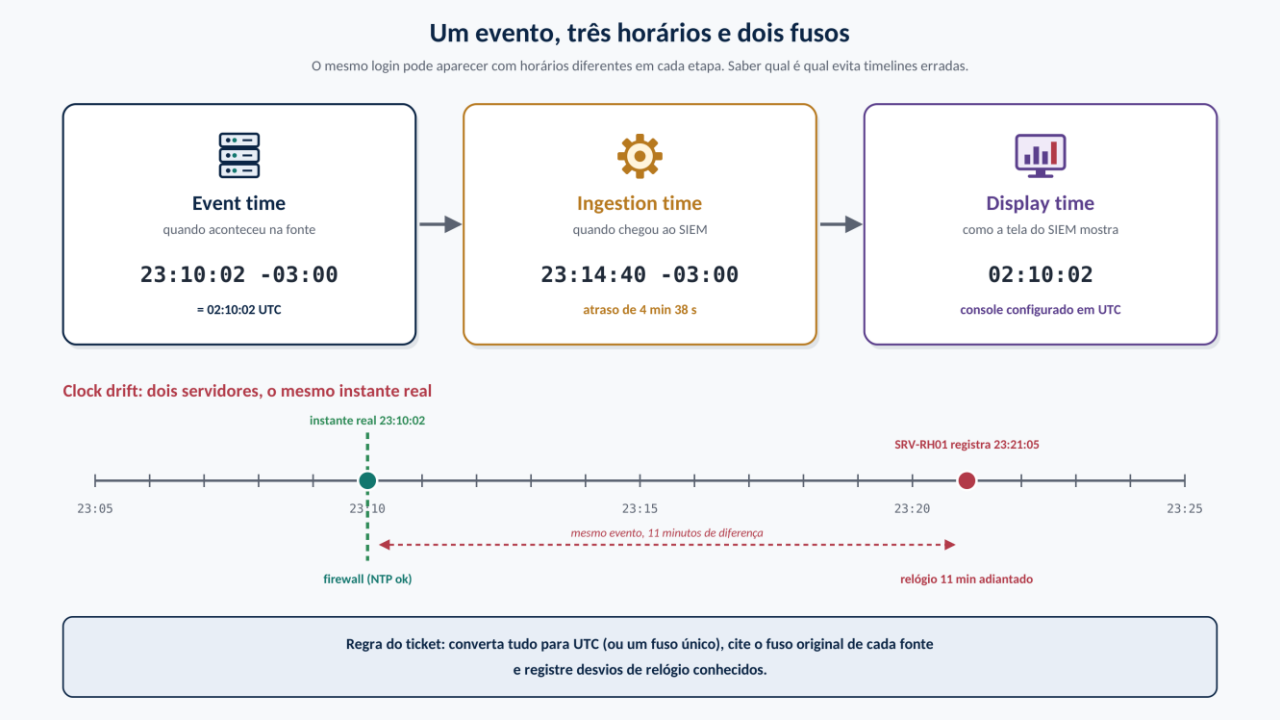


Figura 5.2: Event time, ingestion time e display time; e o efeito do clock drift

UTC, horário local e ISO 8601

- **UTC** (Tempo Universal Coordenado) é a referência mundial, sem horário de verão. Muitos sistemas registram em UTC internamente.
- **Horário de Brasília** é UTC-3 (`-03:00`). O Brasil **não adota horário de verão desde 2019**, o que simplifica as contas; mas fontes no exterior e logs antigos ainda podem ter mudanças de horário.
- **ISO 8601** é o formato que elimina ambiguidade: `2026-11-06T23:10:02-03:00` e `2026-11-07T02:10:02Z` são **o mesmo instante**. O `Z` significa UTC.
- **Datas ambíguas:** `06/11/2026` é 6 de novembro no Brasil e 11 de junho nos Estados Unidos. Em ticket, use `2026-11-06`.

Fusos que você vai encontrar

Local	Offset	Observação
UTC	+00:00 (Z)	Referência; sem horário de verão.
Brasília, São Paulo, Rio, Sul, Nordeste	-03:00	Sem horário de verão desde 2019.
Fernando de Noronha	-02:00	
Manaus, Cuiabá, Campo Grande, Porto Velho	-04:00	Filiais na região Norte/Centro-Oeste.
Rio Branco (Acre)	-05:00	
Lisboa	+00:00 no inverno, +01:00 no verão europeu	Muda duas vezes por ano.
Nova York	-05:00 no inverno, -04:00 no verão	Fornecedores e nuvem nos EUA.
São Francisco	-08:00 no inverno, -07:00 no verão	Muitos SaaS registram aqui ou em UTC.

Conversão passo a passo: o evento diz `2026-11-06T23:10:02-03:00`. O offset `-03:00` significa "3 horas atrás do UTC". Para chegar ao UTC, **some** 3 horas: 23:10:02 + 3 h = 02:10:02 do **dia seguinte**. Resultado: `2026-11-07T02:10:02Z`. Para ir de UTC para Brasília, subtraia 3 horas. Cuidado com a virada do dia: é ali que nascem as timelines "impossíveis".

Formato	Exemplo	Comentário
ISO 8601 com fuso	`2026-11-06T23:10:02-03:00`	O ideal: inequívoco.
ISO 8601 em UTC	`2026-11-07T02:10:02Z`	Comum em nuvem, EDR e APIs.
Epoch (Unix time)	`1793970131`	Segundos desde 1970-01-01 00:00:00 UTC; sempre UTC. Versões em milissegundos têm 13 dígitos.
Syslog tradicional (RFC 3164)	`Nov  6 10:02:11`	**Sem ano e sem fuso.** Depende da configuração do host e do coletor.
Windows (Event Viewer)	`06/11/2026 23:10:02`	A tela mostra no fuso da máquina de quem olha; o XML guarda `SystemTime` em UTC.
IIS (W3C)	`2026-11-06 16:02:11`	Por padrão, em UTC, sem indicar isso na linha.
Apache/Nginx	`[06/Nov/2026:13:02:11 -0300]`	Traz o offset na própria linha.

Os três horários de um evento

Horário	O que representa	Por que importa
Event time	Quando a fonte diz que o evento aconteceu.	É o que vai para a timeline (depois de corrigir fuso e drift).
Ingestion time	Quando o evento chegou ao SIEM.	Regras que olham "últimos 5 minutos" pela ingestão perdem ou duplicam eventos atrasados; mede saúde do pipeline.
Display time	Como a interface mostra o horário.	Depende da configuração do console ou do seu perfil; confirme antes de copiar para o ticket.

Clock drift e NTP

Clock drift é o desvio do relógio de uma máquina em relação ao horário correto. Servidores sincronizam com **NTP** (Módulo 1) ou, em domínios Windows, com a hierarquia do domínio. Quando a sincronização falha, o relógio deriva aos poucos: segundos por dia, minutos por mês.

- **Como perceber:** o mesmo fato aparece com horários incompatíveis em fontes diferentes (o firewall registra a conexão às 02:10, o servidor registra o login às 02:21); ou sequências impossíveis (logoff antes do login).
- **Como confirmar:** `w32tm /query /status` e `w32tm /stripchart` no Windows; `timedatectl` e `chronyc tracking` no Linux; comparar com uma fonte de referência sincronizada.
- **Como documentar:** registre o desvio medido, a evidência e a correção aplicada na timeline ("horário do SRV-RH01 corrigido em -660 s").
- **Impacto além da investigação:** Kerberos falha com diferença de poucos minutos (5 minutos por padrão), e certificados podem parecer inválidos.

```
# Linux: conversões
date -u -d @1793970131                                  # epoch para UTC
TZ=America/Sao_Paulo date -d @1793970131                # epoch para Brasília
date -u -d '2026-11-06T23:10:02-03:00' +%FT%TZ      # local para UTC
TZ=America/Sao_Paulo date -d '2026-11-07T02:21:05Z' # UTC para Brasília
timedatectl                                             # fuso e sincronização do host
chronyc tracking                                        # desvio em relação ao servidor NTP

# PowerShell
[DateTimeOffset]::FromUnixTimeSeconds(1793970131).UtcDateTime
[DateTimeOffset]::Parse('2026-11-06T23:10:02-03:00').UtcDateTime
(Get-Date).ToUniversalTime().ToString('o')              # agora, em UTC, ISO 8601
w32tm /query /status                                    # fonte de hora e última sincronização
w32tm /stripchart /computer:dc01.corp.local /samples:3 /dataonly   # desvio em relação ao DC
```

MOMENTO SOC

Ticket: "Acesso às 02:10."

N2: "02:10 em qual fuso?"

Analista: "...no fuso do SIEM?"

N2: "E o SIEM está em qual fuso?"

> Silêncio no canal. Escreva sempre o fuso. Sempre.

5.5 Formatos e normalização

Cada fonte escreve log do seu jeito. Reconhecer o formato ajuda a saber onde está cada campo e o que pode estar faltando.

Formato	Como reconhecer	Onde aparece	Atenção
Syslog RFC 3164	`<PRI>Mmm dd hh:mm:ss host processo: mensagem`	Linux antigo, equipamentos de rede.	Sem ano, sem fuso, mensagem livre.
Syslog RFC 5424	`<PRI>1 2026-11-06T13:02:11.483Z host app procid msgid ...`	Sistemas mais novos.	Tem ano, fuso e campos estruturados.
CEF	`CEF:0|Fabricante|Produto|Versão|ID|Nome|Severidade|extensões`	Appliances de segurança enviando a SIEMs.	Cabeçalho fixo + pares chave=valor.
key=value	`srcip=10.0.0.5 dstport=443 action=allow`	Firewalls (FortiGate e outros), VPNs.	Valores com espaço precisam de aspas.
JSON	`{"user":"ana","action":"blocked"}`	Nuvem, EDR, proxies modernos, APIs.	Campos aninhados; um evento por linha (NDJSON).
CSV / W3C	Cabeçalho `#Fields:` ou primeira linha com nomes.	IIS, exportações, planilhas.	Vírgulas dentro de campos; fuso implícito.
XML / EVTX	`<Event><System><EventID>4624</EventID>...`	Windows Event Log.	O arquivo .evtx é binário; leia com Event Viewer ou ferramentas próprias.

```
# Syslog RFC 3164 (PRI 134 = facility local0, severidade informational)
<134>Nov  6 13:02:11 fw01 filterlog: block in on wan1 203.0.113.9 -> 198.51.100.20 tcp 3389

# Syslog RFC 5424
<134>1 2026-11-06T13:02:11.483Z fw01 filterlog 1234 - - block in on wan1 203.0.113.9 ->
198.51.100.20 tcp 3389
```

```
# CEF
CEF:0|FabricanteX|FirewallX|7.2|100|Conexão bloqueada|5|src=203.0.113.9 dst=198.51.100.20
dpt=3389 act=deny rt=Nov 06 2026 13:02:11 UTC

# IIS (W3C): horário em UTC por padrão
#Fields: date time s-ip cs-method cs-uri-stem cs-uri-query s-port c-ip cs(User-Agent) sc-
status time-taken
2026-11-06 16:02:11 10.20.0.31 GET /portal/login.aspx - 443 10.50.0.30
Mozilla/5.0+(Windows+NT+10.0) 200 38
```

Normalização

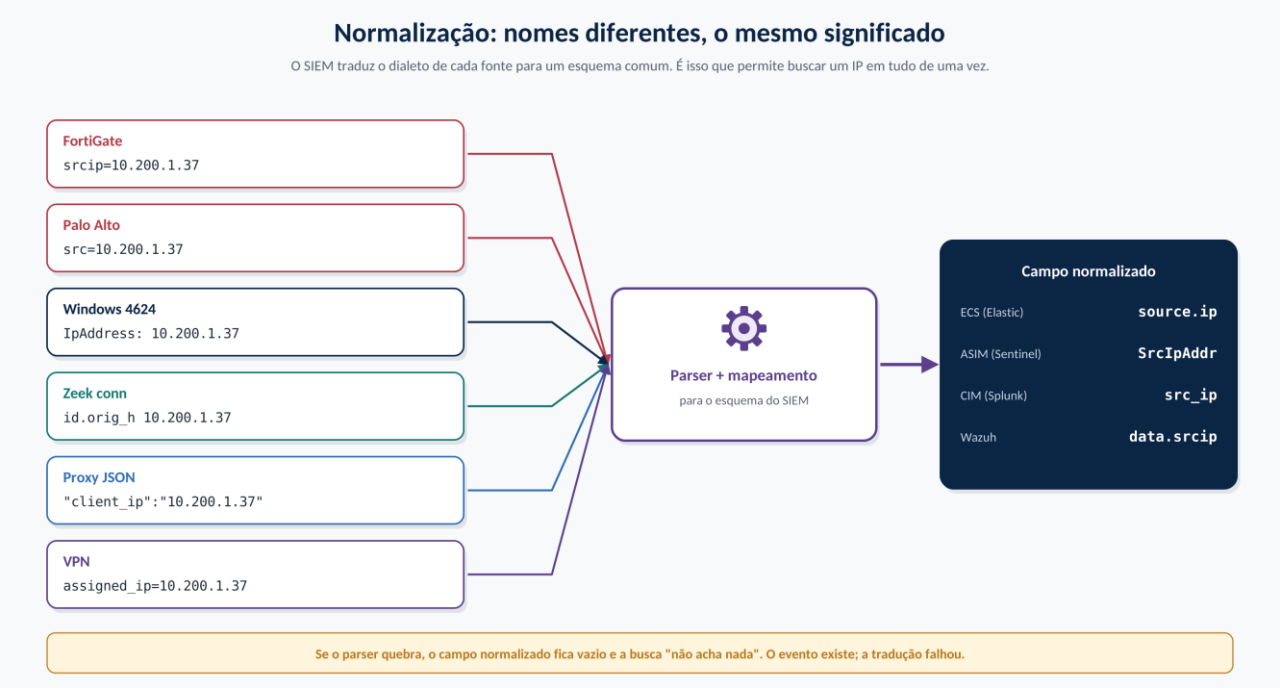


Figura 5.3: Normalização: o mesmo conceito com nomes diferentes vira um campo comum no SIEM

Normalizar é traduzir os campos de cada fonte para um esquema comum. Cada plataforma tem o seu: **ECS** (Elastic Common Schema), **ASIM** (Advanced Security Information Model, do Microsoft Sentinel), **CIM** (Common Information Model, do Splunk). Para o N1, a consequência prática é dupla:

- Buscas pelo campo normalizado alcançam todas as fontes de uma vez (`src_ip = 10.200.1.37` encontra firewall, VPN e Windows).
- Quando o **parser quebra** (o fabricante mudou o formato numa atualização, por exemplo), o campo normalizado fica vazio. A busca não acha nada, mas o evento bruto está lá. Na dúvida, procure também no texto bruto (`raw`, `_raw`, `message`).

Do bruto ao enriquecido

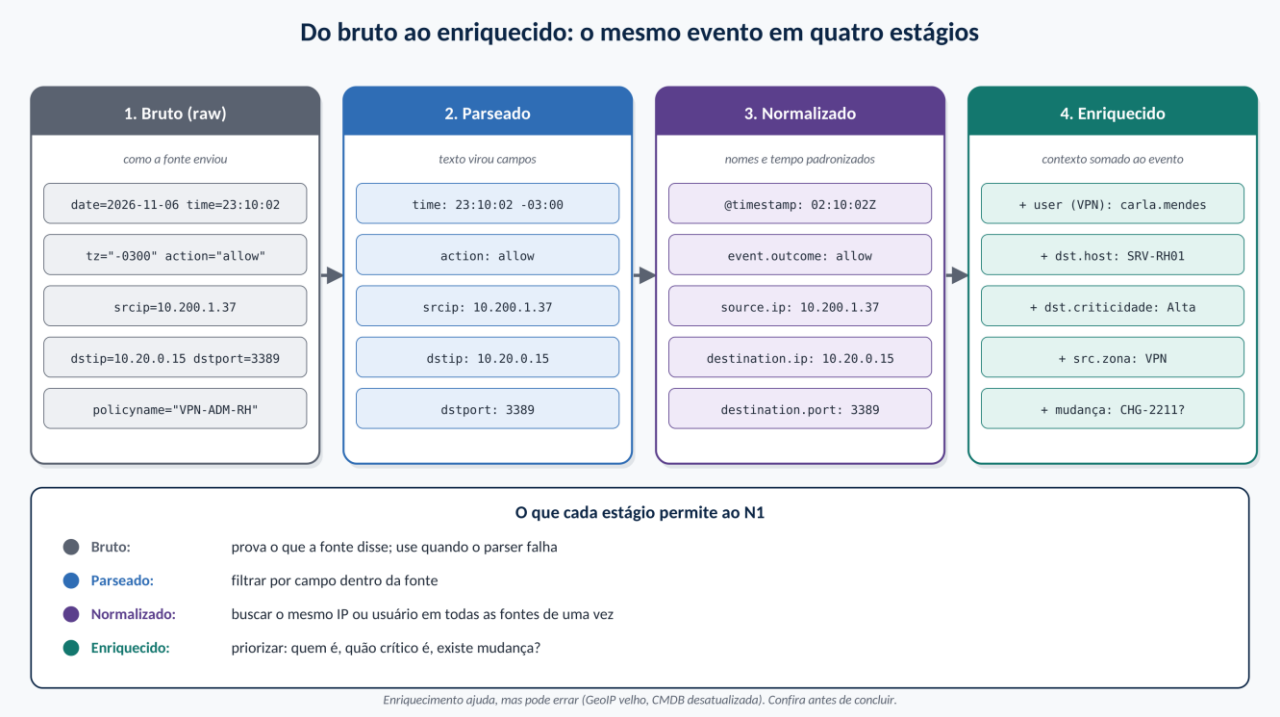


Figura 5.4: O mesmo evento como a fonte enviou, parseado, normalizado e enriquecido

No SIEM, o mesmo evento costuma existir em quatro estágios. O **bruto** é a prova do que a fonte disse. O **parseado** separa o texto em campos. O **normalizado** dá nomes e horário padronizados. O **enriquecido** acrescenta contexto: quem é o usuário por trás do IP, que ativo é o destino, qual sua criticidade, se existe mudança aprovada, qual a reputação de um IP externo.

> **DICA**
>
> Enriquecimento erra. GeoIP desatualizado põe um IP brasileiro na Holanda; CMDB velha diz que o servidor é uma impressora. Use o contexto para priorizar, mas confirme antes de escrever no ticket.

5.6 Logs comentados, fonte por fonte

Todos os exemplos são **sintéticos** e simplificados para ensino. Campos variam conforme versão, fabricante e configuração. IPs são privados ou reservados para documentação.

Windows (Security 4624)

O Event Viewer mostra o horário no fuso da máquina de quem olha; o XML do evento guarda `SystemTime` em UTC. Tipos de logon e demais Event IDs estão no Módulo 3.

```
Log Name: Security    Event ID: 4624    Computer: SRV-FILE01.corp.local
TimeCreated SystemTime: 2026-11-06T13:02:11.4830000Z
Logon Type: 3
New Logon:   Account Name: ana.lima   Account Domain: CORP   Logon ID: 0x3E7A1B
Network Information:   Workstation Name: NB-FIN-042   Source Network Address: 10.10.0.87
Source Port: 0
Detailed Authentication Information:   Logon Process: Kerberos   Authentication Package:
Kerberos
```

Leitura campo a campo:

- `SystemTime` em UTC: 13:02:11 UTC = 10:02:11 em Brasília.
- `Computer` é o destino (onde o logon aconteceu); `Source Network Address` é a origem.
- `Logon ID` é a chave para ligar este logon a eventos posteriores da mesma sessão (e ao 4634 de logoff).
- Logon tipo 3 é autenticação pela rede (ex.: acesso a compartilhamento), não sessão interativa.

Leitura de SOC	
O que procuro	Conta, tipo de logon, origem, destino, pacote de autenticação e Logon ID.
Pode ser benigno	Acesso a compartilhamento em horário comercial, a partir da estação do próprio usuário.
Pode ser suspeito	Origem incomum para a conta, conta privilegiada em host fora do padrão, logons em muitos destinos em pouco tempo.
Próximo passo	Mapear a origem (DHCP, CMDB), verificar o histórico da conta e eventos seguintes com o mesmo Logon ID.
Quando escalo	Logon de conta privilegiada sem justificativa ou padrão de movimento lateral.

Linux (sshd em /var/log/auth.log)

Formato syslog tradicional: repare que **não há ano nem fuso** na linha.

```
Nov  6 10:02:11 web01 sshd[2211]: Accepted publickey for deploy from 10.99.0.10 port 50122
ssh2: ED25519 SHA256:k3J9xQ...
Nov  6 10:04:40 web01 sshd[2290]: Failed password for invalid user admin from 203.0.113.9 port
51022 ssh2
Nov  6 10:04:42 web01 sshd[2290]: Connection closed by invalid user admin 203.0.113.9 port
51022 [preauth]
```

Leitura campo a campo:

- Horário sem ano e sem fuso: confirme o fuso do host (`timedatectl`) e como o coletor interpreta a linha.
- `[2211]` é o PID do processo sshd que atendeu a conexão; agrupa as linhas da mesma conexão.
- `Accepted publickey`: login bem-sucedido com chave; o fingerprint (SHA256:...) identifica qual chave.
- `Failed password for invalid user admin`: tentativa com usuário que nem existe no host; típico de varredura automatizada.

Leitura de SOC	
O que procuro	Sucessos x falhas, usuário, origem, método (senha ou chave), fingerprint da chave.
Pode ser benigno	Deploy automatizado a partir do servidor de CI conhecido; falhas de usuários inexistentes vindas da internet num servidor exposto (ruído constante).
Pode ser suspeito	Sucesso após muitas falhas da mesma origem; login de conta de serviço a partir de origem nova; chave desconhecida.
Próximo passo	Verificar se houve sucesso, de onde, com qual chave e o que a sessão fez em seguida.
Quando escalo	Login bem-sucedido não explicado, especialmente após tentativas, ou em servidor crítico.

Firewall (key=value)

Já visto nos Módulos 1 e 2; aqui o foco é o horário e a direção.

```
date=2026-11-06 time=23:10:02 tz="-0300" devname="FW-CORE01" action="allow" policyid=52
policyname="VPN-ADM-RH"
srcip=10.200.1.37 srcport=52811 dstip=10.20.0.15 dstport=3389 proto=6 service="RDP"
duration=3096 sentbyte=2810331 rcvdbyte=19022871
```

Leitura campo a campo:

- Horário local com fuso explícito (`tz="-0300"`): 23:10:02 local = 02:10:02 UTC.
- `duration=3096` permite calcular o fim da sessão: 02:10:02 + 3096 s = 03:01:38 UTC.
- `policyname` mostra por que foi permitido; compare com a política esperada.
- Bytes nos dois sentidos dão a ideia de volume e direção.

Leitura de SOC	
O que procuro	Direção, serviço, regra, duração e volume.
Pode ser benigno	Acesso permitido por regra documentada, em janela coerente.
Pode ser suspeito	Allow inesperado, regra ampla, volume assimétrico.
Próximo passo	Identificar quem estava atrás do IP de origem (VPN, DHCP) e o que aconteceu no destino.
Quando escalo	Comunicação com destino malicioso ou acesso não autorizado a ativo crítico.

Proxy (JSON, um evento por linha)

```
{"time":"2026-11-06T10:02:11-
03:00","user":"ana.lima@empresa.example","src":"10.10.0.87","method":"GET",
 "url":"https://downloads.exemplo-cdn.example/instalador.msi","category":"Software
Downloads","action":"allowed",
 "status":200,"bytes_in":48211033,"bytes_out":1022,"content_type":"application/x-
msi","user_agent":"Mozilla/5.0 (Windows NT 10.0; Win64; x64)"}
```

Leitura campo a campo:

- `user` liga a navegação a uma pessoa sem depender de DHCP e NAT.
- `category` e `action` mostram a decisão do proxy; `status` é a resposta do site.
- `content_type` e `bytes_in` mostram que foi um download de instalador de 48 MB.
- `user_agent` de navegador comum; útil para comparar com downloads feitos por scripts.

Leitura de SOC	
O que procuro	Usuário, URL, categoria, ação, tipo de conteúdo, user-agent, volume.
Pode ser benigno	Instalador de software conhecido baixado do site oficial do fabricante.
Pode ser suspeito	Download de executável ou script de domínio novo ou sem categoria; user-agent de ferramenta de linha de comando em estação de usuário.

Leitura de SOC	
Próximo passo	Verificar no EDR se o arquivo foi executado e o que aconteceu depois.
Quando escalo	Download seguido de execução suspeita ou destino malicioso confirmado.

DNS (resolver, JSON)

```
{"ts":"2026-11-06T13:02:09.112Z","client":"10.10.0.87","query":"downloads.exemplo-
cdn.example","qtype":"A",
 "rcode":"NOERROR","answers":["203.0.113.44"],"ttl":300}
```

Leitura campo a campo:

- A consulta precede a conexão: 2 segundos depois, o proxy registra o download do mesmo domínio.
- `answers` liga o nome ao IP que aparecerá no firewall.
- `rcode` NOERROR resolveu; NXDOMAIN em massa seria outra história (Módulo 1).
- Consulta não prova conexão; a conexão está no proxy/firewall.

Leitura de SOC	
O que procuro	Cliente, nome, tipo de registro, resposta e TTL.
Pode ser benigno	Domínios de fabricantes e serviços conhecidos.
Pode ser suspeito	Domínios recém-criados, padrões de DGA ou tunneling, resolução por processo incomum.
Próximo passo	Confirmar se houve conexão e qual processo consultou (Sysmon 22, EDR).
Quando escalo	Resolução de domínio malicioso seguida de conexão.

VPN

```
2026-11-07T02:05:40Z vpn-gw01 event=auth_success user=carla.mendes src_ip=203.0.113.45
src_country=BR
  assigned_ip=10.200.1.37 mfa=push_approved mfa_attempts=1 device=NB-RH-007
device_managed=true
```

Leitura campo a campo:

- Horário em UTC (`Z`): 02:05:40 UTC = 23:05:40 do dia anterior em Brasília.
- `assigned_ip` é o elo com o resto da rede: tudo que 10.200.1.37 fizer nesta sessão é desse usuário.
- `mfa_attempts=1` e `device_managed=true` são sinais de normalidade; compare com o Módulo 1, seção 1.17.

Leitura de SOC	
O que procuro	Usuário, IP público, país/ASN, MFA, dispositivo, IP atribuído, duração e bytes.
Pode ser benigno	Plantão ou trabalho remoto planejado, dispositivo gerenciado, MFA na primeira tentativa.
Pode ser suspeito	Origem anônima ou incomum, muitas tentativas de MFA, dispositivo não gerenciado.
Próximo passo	Seguir o IP atribuído nos logs internos durante a sessão.

Leitura de SOC	
Quando escalo	Sinais combinados de comprometimento de conta.

EDR (evento de processo, JSON)

```
{"timestamp":"2026-11-06T13:05:31.902Z","device":"NB-FIN-
042","user":"CORP\\ana.lima","event":"ProcessCreated",
 "process":{"name":"msiexec.exe","path":"C:\\Windows\\System32\\msiexec.exe",
   "cmdline":"msiexec.exe /i
C:\\Users\\ana.lima\\Downloads\\instalador.msi","sha256":"9f2c...e41a"},
 "parent":{"name":"explorer.exe","path":"C:\\Windows\\explorer.exe"},"signature":"Microsoft
Windows","verdict":"none"}
```

Leitura campo a campo:

- O EDR liga o download do proxy (13:02) à execução (13:05) pelo caminho do arquivo e pelo usuário.
- `parent` explorer.exe: o próprio usuário abriu o instalador pelo Windows Explorer.
- `sha256` do instalador permite consultar reputação e buscar o mesmo arquivo em outras máquinas.
- `verdict` none: o EDR não classificou como malicioso; isso é contexto, não absolvição.

Leitura de SOC	
O que procuro	Processo, caminho, linha de comando, processo pai, usuário, hash, assinatura e eventos seguintes.
Pode ser benigno	Instalação de software aprovado pelo próprio usuário com permissão para isso.
Pode ser suspeito	Cadeias pai-filho incomuns, execução a partir de pastas temporárias, hash desconhecido com comportamento de rede estranho.
Próximo passo	Ver a árvore de processos e as conexões após a execução; consultar o hash.
Quando escalo	Execução maliciosa confirmada ou comportamento sem explicação em ativo sensível.

WAF (JSON)

Como no Módulo 2: verifique sempre a ação.

```
{"timestamp":"2026-11-06T13:02:11-
03:00","client_ip":"203.0.113.150","host":"portal.empresa.example","request_id":"a7f3c2",

"method":"GET","uri":"/produtos.aspx?id=10%27%20OR%20%271%27=%271","rule_id":"942100","action":"BLOCK","sta
```

Leitura campo a campo:

- `uri` vem codificada: `%27` é aspas simples, `%20` é espaço.
- `action` BLOCK e `status` 403: o WAF barrou esta requisição.
- `request_id` permite achar a mesma requisição nos logs do load balancer e da aplicação, quando propagado.

Leitura de SOC	
O que procuro	Ação, regra, alvo (URL e parâmetro), origem, volume e variações de payload.
Pode ser benigno	Scanner autorizado; conteúdo legítimo de formulário parecido com ataque.
Pode ser suspeito	Requisições que passaram (status 200) com resposta anormal; ataque contínuo a aplicação crítica.
Próximo passo	Se passou, seguir no servidor web e na aplicação.
Quando escalo	Indício de que a requisição maliciosa teve sucesso.

E-mail (rastreamento de mensagens)

```
Received: 2026-11-06T12:41:07Z   MessageId: <a1b2c3@mail.fornecedor-exemplo.example>
SenderAddress: financeiro@fornecedor-exemplo.example   RecipientAddress:
ana.lima@empresa.example
Subject: "Atualização de dados bancários"   FromIP: 203.0.113.61   Status: Delivered
SPF: fail   DKIM: none   DMARC: fail (p=none)
```

Leitura campo a campo:

- `MessageId` identifica a mensagem; busque o mesmo ID para achar todos os destinatários.
- SPF falhou e DMARC falhou, mas foi entregue: a política do domínio remetente é `p=none` (só monitora). Detalhes no Módulo 9.
- Assunto de troca de dados bancários: tema clássico de fraude de pagamento.

Leitura de SOC	
O que procuro	Remetente, destinatários, IP de origem, autenticação (SPF/DKIM/DMARC), status, anexos e links.
Pode ser benigno	Fornecedor real com SPF mal configurado enviando comunicado comum.
Pode ser suspeito	Pedido de alteração bancária, urgência, domínio parecido com o de fornecedor, autenticação falhando.
Próximo passo	Buscar a campanha inteira, verificar cliques e respostas, seguir o Playbook de phishing (Módulo 17).
Quando escalo	Destinatário respondeu, clicou ou executou algo; alvo é financeiro ou executivo.

Active Directory (4740 e 4728)

Eventos registrados nos controladores de domínio. Detalhes de identidade no Módulo 8.

```
EventID 4740  TimeCreated: 2026-11-06T14:20:03Z  Computer: DC01.corp.local
  A user account was locked out.  TargetUserName: joao.pereira  CallerComputerName: NB-TI-014

EventID 4728  TimeCreated: 2026-11-06T14:31:10Z  Computer: DC01.corp.local
  A member was added to a security-enabled global group.
  SubjectUserName: adm.infra   MemberName: CN=Paulo Souza,OU=TI,DC=corp,DC=local
TargetUserName: GRP-VPN-RH
```

Leitura campo a campo:

- 4740: a conta foi bloqueada; `CallerComputerName` mostra de qual máquina vieram as tentativas que causaram o bloqueio.
- 4728: alguém (`SubjectUserName`) adicionou um membro (`MemberName`) a um grupo (`TargetUserName`).
- Para 4728 a pergunta sempre é: existe chamado ou mudança aprovada para essa inclusão?

Leitura de SOC	
O que procuro	Conta afetada, origem do bloqueio, quem alterou grupo, qual grupo e qual membro.
Pode ser benigno	Senha antiga salva em dispositivo; inclusão em grupo com chamado aprovado.
Pode ser suspeito	Bloqueios em muitas contas a partir de uma origem; inclusão em grupo privilegiado sem chamado.
Próximo passo	Verificar a origem do bloqueio e o chamado da alteração.
Quando escalo	Alteração não autorizada em grupo privilegiado ou bloqueios em massa.

Windows (Security 4625: falha de logon)

O 4625 traz códigos que dizem **por que** o logon falhou. Ler o código muda a triagem.

```
EventID 4625   TimeCreated SystemTime: 2026-11-06T14:12:40.120Z   Computer: SRV-
FILE01.corp.local
Account For Which Logon Failed:   Account Name: joao.pereira   Account Domain: CORP
Failure Information:   Status: 0xC000006D   Sub Status: 0xC000006A
Logon Type: 3   Workstation Name: NB-TI-014   Source Network Address: 10.10.0.52
```

Leitura campo a campo:

- `Sub Status` 0xC000006A: a conta existe e a senha está errada.
- Logon tipo 3 vindo de NB-TI-014: tentativa pela rede (por exemplo, unidade mapeada).
- Muitas falhas como esta seguidas de 4740 explicam um bloqueio de conta.

Leitura de SOC	
O que procuro	Conta, código de falha, origem, tipo de logon, volume e se houve sucesso depois.
Pode ser benigno	Senha antiga salva em dispositivo ou mapeamento após troca de senha.
Pode ser suspeito	Muitas contas diferentes a partir de uma origem; usuários inexistentes; sucesso logo após falhas.
Próximo passo	Agrupar por conta e origem; verificar 4624 posteriores da mesma origem.
Quando escalo	Padrão de spraying ou sucesso suspeito após falhas.

Código (Status / Sub Status)	Significado	Leitura de triagem
`0xC000006A`	Senha incorreta (conta existe)	Erro de digitação, senha antiga salva, ou tentativa de adivinhar.

Código (Status / Sub Status)	Significado	Leitura de triagem
0xC0000064	Usuário não existe	Em volume, indica enumeração ou lista de usuários genérica.
0xC0000234	Conta bloqueada	Consequência de falhas anteriores; procure a origem no 4740.
0xC0000072	Conta desabilitada	Ex-funcionário ou conta inativa sendo usada: merece pergunta.
0xC000006F	Fora do horário permitido	Restrição de horário configurada para a conta.
0xC0000071	Senha expirada	Normalmente operacional.
0xC0000193	Conta expirada	Conta temporária ou de terceiro após a data limite.

Linux (sudo)

O sudo registra quem elevou privilégio, como quem e para fazer o quê.

```
Nov  6 22:51:30 srv-app-01 sudo:   deploy : TTY=pts/0 ; PWD=/home/deploy ; USER=root ;
COMMAND=/usr/bin/systemctl restart nginx
Nov  6 22:51:30 srv-app-01 sudo: pam_unix(sudo:session): session opened for user root(uid=0)
by deploy(uid=1001)
```

Leitura campo a campo:

- Quem: `deploy`. Como quem: `USER=root`. O quê: `COMMAND=...`. De onde: `TTY=pts/0` (sessão remota, normalmente SSH).
- Como todo syslog tradicional, sem ano e sem fuso.
- A sessão do PAM confirma que a elevação aconteceu.

Leitura de SOC	
O que procuro	Usuário, comando, terminal, horário e se existe mudança aprovada.
Pode ser benigno	Reinício de serviço em janela de manutenção pela conta de deploy.
Pode ser suspeito	Comandos fora do padrão da conta, fora de janela, ou que alteram contas, chaves e logs.
Próximo passo	Relacionar com o login SSH (mesma sessão) e com o chamado de mudança.
Quando escalo	Elevação não explicada em servidor crítico.

DHCP (Windows Server)

Fonte essencial para atribuição: diz qual máquina tinha cada IP em cada momento (Módulo 1, seção 1.10). O arquivo é DhcpSrvLog, em horário local.

```
ID,Date,Time,Description,IP Address,Host Name,MAC Address
10,11/06/26,07:51:03,Assign,10.10.0.87,NB-FIN-042.corp.local,3C5282112233
11,11/06/26,11:51:04,Renew,10.10.0.87,NB-FIN-042.corp.local,3C5282112233
12,11/06/26,18:02:40,Release,10.10.0.87,NB-FIN-042.corp.local,3C5282112233
```

Leitura campo a campo:

- ID 10 = nova concessão; 11 = renovação; 12 = liberação.
- Data no formato **MM/DD/AA** (americano): `11/06/26` é 6 de novembro.
- Entre 07:51 e 18:02 (local), 10.10.0.87 era NB-FIN-042. Fora desse intervalo, pode ser outra máquina.

Leitura de SOC	
O que procuro	IP, hostname, MAC e o intervalo em que a concessão valia.
Pode ser benigno	Renovações regulares durante o expediente.
Pode ser suspeito	Hostnames fora do padrão, MACs desconhecidos, servidor DHCP não autorizado.
Próximo passo	Registrar no ticket "IP X era o host Y entre A e B".
Quando escalo	Dispositivo não autorizado envolvido em atividade suspeita.

Nuvem: sign-in do Entra ID

Logins em Microsoft 365 e aplicações que usam o Entra ID não passam pelos controladores de domínio. Este é o log que conta essa parte da história.

```
TimeGenerated=2026-11-06T14:20:11Z UserPrincipalName=bruno.costa@empresa.example
IPAddress=203.0.113.150
AppDisplayName="Office 365 Exchange Online" ClientAppUsed=Browser ResultType=50126 Location=BR
TimeGenerated=2026-11-06T14:20:14Z UserPrincipalName=ana.lima@empresa.example
IPAddress=203.0.113.150 ResultType=50126
TimeGenerated=2026-11-06T14:20:17Z UserPrincipalName=carla.mendes@empresa.example
IPAddress=203.0.113.150 ResultType=50126
```

Leitura campo a campo:

- `ResultType` 50126: usuário ou senha inválidos.
- O mesmo IP tentando contas diferentes em segundos: padrão de **password spraying**.
- `AppDisplayName` e `ClientAppUsed` mostram por onde tentaram.

Leitura de SOC	
O que procuro	Usuário, IP, aplicação, resultado, MFA, acesso condicional e dispositivo.
Pode ser benigno	Usuário errando a própria senha algumas vezes.
Pode ser suspeito	Um IP contra muitas contas; sucesso após falhas; MFA negado repetidamente.
Próximo passo	Agrupar por IP e por conta; verificar se alguma tentativa teve sucesso.
Quando escalo	Qualquer sucesso associado ao padrão de spraying ou MFA fatigue.

ResultType	Significado	Leitura de triagem
`0`	Sucesso	Verifique de onde, com qual dispositivo e o que veio depois.
`50126`	Usuário ou senha inválidos	Em volume a partir de um IP, spraying.

ResultType	Significado	Leitura de triagem
50053	Conta bloqueada (ou IP marcado como malicioso)	Consequência de tentativas; veja a origem.
50074	MFA exigido	Normal: a senha estava certa e o MFA foi pedido.
500121	Falha durante a autenticação forte (MFA)	Muitas seguidas: possível MFA fatigue ou usuário negando.

5.7 Correlação temporal: montando a timeline

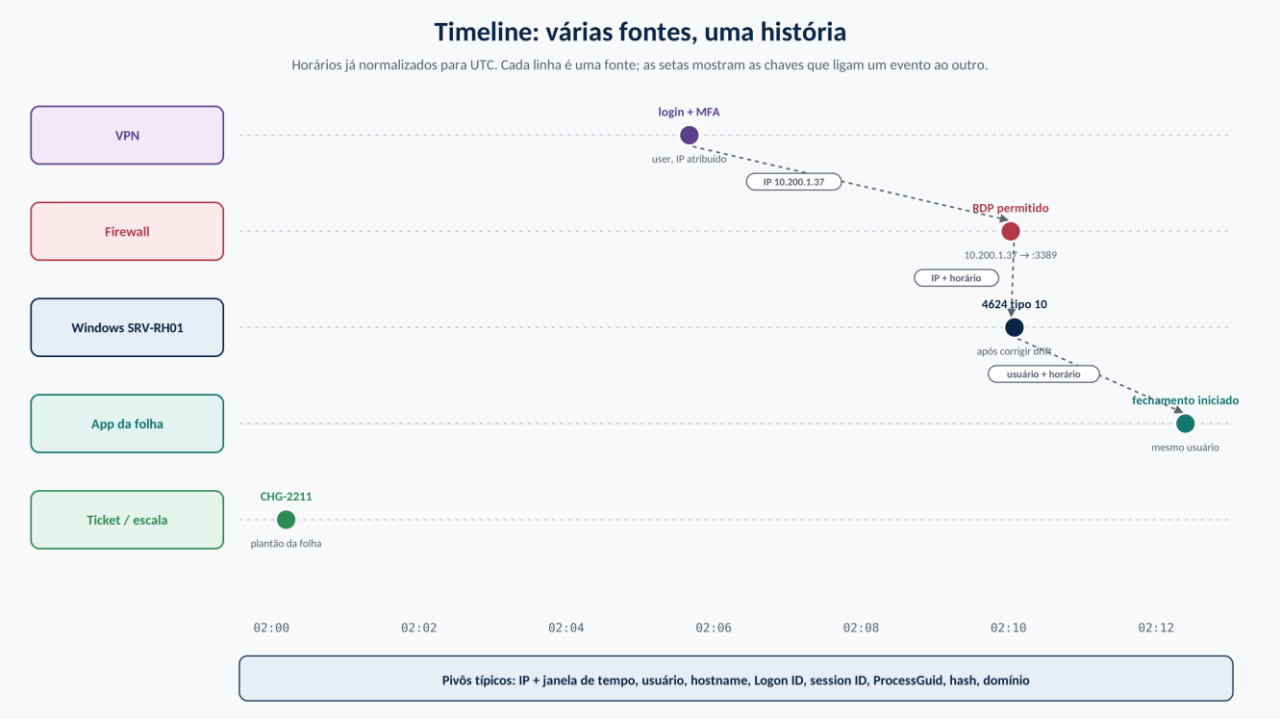


Figura 5.5: Timeline multi-fonte com horários normalizados e chaves de pivô

Correlacionar é ligar eventos de fontes diferentes que pertencem à mesma história. Faça sempre nesta ordem:

1. **Delimite a janela:** comece alguns minutos antes do primeiro evento conhecido e termine depois do último. Amplie se a história pedir.
2. **Liste as fontes** que deveriam ter visto a atividade (matriz de visibilidade do Módulo 2) e confirme que estavam enviando no período.
3. **Normalize o tempo:** tudo em UTC (ou num fuso único declarado), corrigindo drifts conhecidos.
4. **Escolha pivôs:** use chaves que realmente ligam eventos (tabela abaixo), e não apenas a proximidade de horário.
5. **Ordene e descreva:** uma linha por evento: horário UTC, fonte, host, conta, o que aconteceu, evidência (consulta ou ID do registro).
6. **Separe fato de inferência:** "firewall permitiu RDP" é fato; "o usuário abriu a planilha" é inferência se nenhum log mostra isso.
7. **Registre lacunas:** fontes indisponíveis, campos ausentes, correções aplicadas.

Pivô	Liga	Cuidado
IP + janela de tempo	Firewall, proxy, DNS, VPN, Windows	IP muda de dono (DHCP, VPN, NAT); use a janela certa.
Usuário	VPN, AD, proxy, aplicação, e-mail	Formatos diferentes do mesmo nome; contas compartilhadas.
Hostname	EDR, Windows, DHCP, CMDB	Nome curto x FQDN; máquinas renomeadas.
Logon ID / session ID	Eventos da mesma sessão na mesma fonte	Só vale dentro da fonte que o gerou.
ProcessGuid / PID + horário	Eventos do mesmo processo	PID é reutilizado (Módulos 3 e 4).
Hash	O mesmo arquivo em vários hosts	Arquivos levemente diferentes têm hash diferente.
Domínio / URL	DNS, proxy, e-mail, EDR	Subdomínios e redirecionamentos.
Message ID	Todos os destinatários de um e-mail	Formato varia por plataforma.

O QUE UM N1 REALMENTE PRECISA SABER

Proximidade não é causalidade. Dois eventos com 2 segundos de diferença podem não ter nada a ver um com o outro, principalmente em servidores movimentados. A ligação fica forte quando um **pivô** une os dois (mesmo usuário, mesma sessão, mesmo IP atribuído) e a sequência faz sentido técnico.

5.8 Qualidade do log: quando a evidência mente sem querer



Figura 5.6: Oito problemas de qualidade que enganam a investigação

Problema	Sinal	Como verificar
Lacuna	Fonte sem eventos num período em que deveria ter.	Último evento recebido por fonte; consultas de saúde (Módulo 2, seção 2.7).

Problema	Sinal	Como verificar
Atraso de ingestão	Diferença grande entre event time e ingestion time.	Comparar os dois campos; alertas de atraso do SIEM.
Fuso errado	Eventos deslocados em horas cheias (3 h, por exemplo).	Comparar o mesmo fato em duas fontes; ver configuração do parser.
Clock drift	Diferenças de minutos ou segundos, sem padrão de hora cheia.	Comandos de hora no host; comparar com fonte sincronizada.
Duplicado	Eventos idênticos, mesmo ID de registro.	Comparar RecordId/ID do evento e o coletor de origem.
Parser quebrado	Campos vazios, "N/A", IP 0.0.0.0, usuário no campo errado.	Ver o evento bruto; verificar mudanças recentes na fonte.
Truncado	Linha termina no meio; JSON inválido.	Limite de tamanho do coletor ou do syslog.
Retenção	Busca antiga não retorna nada.	Política de retenção do SIEM e da fonte.

NA VIDA REAL

Depois da atualização do firewall, 40% dos eventos chegaram com `src_ip=0.0.0.0`.

A regra de "IP de origem malicioso" ficou silenciosa e o dashboard ficou lindo.

Nenhum ataque foi detectado. Nenhum ataque teria sido detectado.

5.9 Qual log responde a cada pergunta?

Pergunta da investigação	Fonte principal	Confirmação
Quem tinha o IP 10.10.0.87 às 02:14?	DHCP	EDR, CMDB, logon no AD
Quem estava atrás do IP público às 14:02?	Log de NAT do firewall	DHCP, depois logon
Quem estava no IP do pool da VPN?	Concentrador VPN	Logons internos com esse IP
O usuário fez login? De onde?	AD (4624/4625) e IdP de nuvem	VPN, EDR
Por que a conta bloqueou?	DC: 4740 (CallerComputerName) e 4625	Dispositivo de origem
Qual processo fez a conexão?	EDR / Sysmon 3	Firewall para destino e volume
Que domínio a máquina consultou?	DNS (resolver) / Sysmon 22	Proxy, firewall
Qual URL o usuário acessou?	Proxy / SWG	DNS, EDR
Quem recebeu o e-mail?	Rastreamento de mensagens	Logs de clique do gateway
O arquivo foi executado?	EDR (processo criado ou bloqueado)	Security 4688, Sysmon 1
O ataque web chegou à aplicação?	WAF (ação) e log do servidor web	Aplicação, EDR do servidor
Quem foi adicionado ao grupo?	DC: 4728/4732/4756	Chamado de mudança
Quem virou root no Linux?	sudo em auth.log / secure / journald	Login SSH da mesma sessão
Saiu muito dado? Para onde?	Firewall (bytes) e proxy	EDR (processo), DLP

Pergunta da investigação	Fonte principal	Confirmação
A fonte estava enviando logs?	Painel de saúde do SIEM	Último evento por fonte
O relógio da fonte está certo?	Comandos de hora no host	Comparar com fonte sincronizada

5.10 Como citar logs no ticket

Uma evidência bem citada pode ser reencontrada por qualquer pessoa, em qualquer turno. Use sempre o mesmo formato:

```
[2026-11-07T02:10:02Z] FW-CORE01 (firewall interno; horário original -03:00)
  Fato:          allow RDP 10.200.1.37:52811 -> 10.20.0.15:3389, regra VPN-ADM-RH, duração
3096 s
  Como achar:    consulta usada no SIEM ou ID do evento
  Interpretação: início da sessão RDP de carla.mendes (IP atribuído pela VPN às 02:05:40Z)
  Limitação:     nenhuma para este evento
```

Ruim	Bom
"Usuária acessou o servidor às 23h. Normal, fechando."	"2026-11-07T02:10:02Z (23:10:02 -03:00): FW-CORE01 permitiu RDP de 10.200.1.37 (VPN de carla.mendes desde 02:05:40Z, MFA na 1ª tentativa, dispositivo gerenciado) para SRV-RH01. 4624 tipo 10 no SRV-RH01 com horário corrigido em -660 s (relógio adiantado, evidência anexada). Atividade coerente com CHG-2211. Classificação: Benigno Positivo."

> **NA VIDA REAL**
>
> "Verificado e normal" não é citação de log. É uma opinião sem endereço.

5.11 Como isso aparece no SOC: três mini-casos

Caso 1: "O horário do alerta não bate"

O alerta diz 02:21 UTC; o firewall mostra a conexão às 02:10 UTC. O analista quase concluiu que eram dois acessos diferentes. A verificação de hora no servidor mostrou relógio 11 minutos adiantado. **Conclusão:** um único acesso; timeline corrigida e chamado aberto para infraestrutura ajustar a sincronização. Este é o cenário do Lab 5.4.

Caso 2: "Busquei o IP e não achei nada"

A busca por `src_ip=10.10.0.66` não retornou eventos do firewall, embora o firewall estivesse enviando logs. No evento bruto, o IP aparecia normalmente; o parser estava gravando o campo como `srcip` sem normalizar após uma atualização. **Conclusão:** o evento existia; a busca é que estava cega. Registrado no ticket e reportado ao SIEM Engineer.

Caso 3: "Dois acessos idênticos no mesmo milissegundo"

Dois 4624 com exatamente os mesmos campos e o mesmo RecordId, diferindo só no coletor. **Conclusão:** um único evento enviado por dois coletores. Não é um segundo acesso, mas é um problema de pipeline que infla contagens e pode disparar regras de volume.

5.12 Comandos para ler logs

No SIEM você vai usar a linguagem de consulta da plataforma (Módulo 6). Mesmo assim, é comum receber arquivos exportados, e estes comandos resolvem a maior parte das necessidades. Use-os em cópias, nunca no original da evidência.

```
# Linux: arquivos de texto
less /var/log/auth.log                          # ler com rolagem e busca (/texto)
tail -f /var/log/syslog                         # acompanhar em tempo real
grep 'Failed password' auth.log | wc -l         # contar falhas
grep 'Failed password' auth.log | awk '{print $(NF-3)}' | sort | uniq -c | sort -rn | head   #
IPs com mais falhas
cut -d, -f1,2,4 srv-rh01_security.csv           # escolher colunas de um CSV
sort srv-rh01_security.csv | uniq -d            # linhas exatamente duplicadas
jq -r 'select(.action=="blocked") | [.time,.user,.url] | @tsv' proxy.json   # filtrar JSON
journalctl -u ssh --since "2026-11-06 22:00" --until "2026-11-07 01:00" -o short-iso
journalctl -o json -n 5 | jq .                  # o mesmo evento, estruturado
sha256sum vpn_gateway.log                       # registrar o hash da evidência recebida

# PowerShell
Get-Content .\proxy.json | ConvertFrom-Json | Where-Object action -eq 'blocked'
Import-Csv .\srv-rh01_security.csv | Group-Object EventID | Select-Object Name, Count
Select-String -Path .\firewall_interno.log -Pattern 'dstport=3389'
Get-FileHash .\vpn_gateway.log -Algorithm SHA256
```

5.13 Ferramentas

Ferramenta	Para que serve	Gratuita?
SIEM (Wazuh, Elastic, Sentinel, Splunk)	Buscar, correlacionar e montar timelines em escala.	Wazuh e Elastic, sim
grep, awk, cut, sort, uniq, jq	Ler e filtrar arquivos exportados.	Sim
PowerShell	Ler CSV, JSON e eventos do Windows.	Sim
Event Viewer	Ler logs do Windows (inclusive .evtx exportados).	Nativo
Timeline Explorer (Eric Zimmerman)	Abrir CSVs grandes de timeline com filtros.	Sim
LibreOffice Calc / Excel	Montar a timeline final ordenada.	Calc, sim
CyberChef	Decodificar Base64, URL encoding, converter horários.	Sim (use a versão offline para dados sensíveis)

> ⛔ **ATENÇÃO**
>
> Nunca cole logs com dados pessoais, credenciais ou informações de clientes em ferramentas online. Para decodificar ou converter, use ferramentas locais ou a versão offline.

Fechamento do Módulo 5

Laboratórios

São sete laboratórios, do campo isolado à timeline completa. Os Labs 5.4, 5.6 e 5.7 usam arquivos fictícios que estão **reproduzidos neste documento** e também no anexo embutido **Lab_Modulo05_logs.zip** (uma pasta por laboratório). Os gabaritos ficam no fim do módulo.



Anexo: Lab_Modulo05_logs.zip. No Word para Windows, clique duas vezes no ícone. Em Word para Mac, Word Online ou LibreOffice o ícone pode não abrir; use a cópia entregue separadamente ou o conteúdo reproduzido abaixo.

Lab 5.1: Anatomia na sua máquina

Item	Descrição
Objetivo	Encontrar os campos essenciais em eventos reais do seu computador e perceber a diferença entre horário exibido e horário registrado.
Duração	30 a 40 minutos
Pré-requisitos	Computador próprio (Windows ou Linux); Módulo 3 ou 4 para contexto.

Passo a passo (Windows):

1. Abra o Visualizador de Eventos (`eventvwr.msc`) como administrador → Logs do Windows → Segurança.
2. Filtre pelo ID 4624 e abra um evento recente.
3. Na aba **Detalhes**, escolha **Modo XML** e localize `TimeCreated SystemTime`.
4. Compare com a coluna "Data e Hora" da lista. Anote a diferença.
5. Localize `TargetUserName`, `LogonType`, `IpAddress` e `TargetLogonId`.

Passo a passo (Linux):

1. Rode `journalctl -n 5` e depois `journalctl -n 5 -o json | jq .`
2. No JSON, localize `__REALTIME_TIMESTAMP`, `_HOSTNAME`, `_COMM`, `_PID` e `MESSAGE`.
3. Converta o `__REALTIME_TIMESTAMP` (microssegundos desde 1970) para data: `date -u -d @$((VALOR/1000000))`.

Campo	Evento 1	Evento 2	Evento 3
Quando (UTC)			
Onde (host)			
Quem			
O quê			

Campo	Evento 1	Evento 2	Evento 3
Resultado			
Chave de sessão			

Resultado esperado: no Windows, o `SystemTime` está em UTC e a lista exibe no fuso do computador (em Brasília, 3 horas a menos). No Linux, o JSON traz o horário em epoch com microssegundos e o mesmo evento aparece em texto no formato curto. **Entrega:** a tabela preenchida, com "n/d" onde o evento não traz o campo.

Lab 5.2: Tempo

Item	Descrição
Objetivo	Converter horários sem errar a virada do dia e verificar a fonte de hora do seu computador.
Duração	20 a 30 minutos
Pré-requisitos	Terminal Linux (ou WSL) ou PowerShell.

1. Converta para UTC: `2026-11-06T22:15:00-03:00`.
2. Converta o epoch `1793970131` para UTC e para Brasília.
3. Converta `Nov  6 10:02:11` assumindo host em America/Sao_Paulo e ano 2026.
4. Converta `2026-11-07T02:21:05Z` para horário de Brasília.
5. Verifique a sincronização: `w32tm /query /status` (Windows) ou `timedatectl` (Linux). Anote a fonte de hora e se está sincronizado.
6. Descubra em qual fuso o seu SIEM de laboratório exibe os horários (você vai montar no Módulo 25; anote a pergunta).

```
date -u -d '2026-11-06T22:15:00-03:00' +%FT%TZ
date -u -d @1793970131
TZ=America/Sao_Paulo date -d @1793970131
TZ=America/Sao_Paulo date -d '2026-11-07T02:21:05Z'
```

Lab 5.3: Normalização no papel

Item	Descrição
Objetivo	Traduzir quatro formatos diferentes para um esquema comum e registrar o que falta.
Duração	20 minutos
Pré-requisitos	Seção 5.5.

```
1) date=2026-11-06 time=23:10:02 tz="-0300" action="allow" srcip=10.200.1.37 dstip=10.20.0.15
dstport=3389
2) 2026-11-07T02:05:40Z vpn-gw01 event=auth_success user=carla.mendes assigned_ip=10.200.1.37
3) {"time":"2026-11-06T10:02:11-
03:00","user":"ana.lima","src":"10.10.0.87","action":"allowed","url":"https://downloads.exemplo-
cdn.example/instalador.msi"}
```

```
4) <134>1 2026-11-06T13:02:11.483Z fw01 filterlog 1234 - - block in on wan1 203.0.113.9 ->
198.51.100.20 tcp 3389
```

Linha	time_utc	src_ip	dst_ip	dst_port	user	action
1						
2						
3						
4						

Marque "n/d" quando a linha não traz o campo. Esse "n/d" também é informação.

Lab 5.4: Timeline com fusos, drift e duplicata

Item	Descrição
Objetivo	Investigar um alerta de "Acesso RDP fora do horário a servidor de RH" cruzando sete fontes em fusos diferentes.
Duração	60 a 90 minutos
Pré-requisitos	Seções 5.4 e 5.7. Pasta `Lab_5.4_timeline_rh` do anexo.

#	Tarefa
1	Converta todos os horários relevantes para UTC.
2	Identifique a fonte com relógio errado e calcule o desvio.
3	Monte a timeline do acesso, do login na VPN até o fim da sessão.
4	Encontre o evento duplicado e explique por que ele não é um segundo acesso.
5	Classifique o alerta (VP, FP ou BP) e justifique com evidências.
6	Escreva duas recomendações.

Arquivos do laboratório (conteúdo integral):

`LEIA-ME.txt` *Cenário e tarefas*

```
LAB 5.4 - TIMELINE COM FUSOS, DRIFT E DUPLICATA
Todos os dados são FICTÍCIOS e foram criados para treino. IPs são privados ou
reservados para documentação (203.0.113.0/24). Nomes de pessoas são inventados.


CENÁRIO
Sexta-feira, 06/11/2026, à noite (horário de Brasília, UTC-3).
O SIEM abriu o alerta descrito em alerta_siem.json: "Acesso RDP fora do horário
a servidor de RH". O servidor SRV-RH01 guarda dados da folha de pagamento.


ARQUIVOS
alerta_siem.json            alerta gerado pelo SIEM
vpn_gateway.log             concentrador VPN (horário em UTC, sufixo Z)
firewall_interno.log        firewall entre VPN e servidores (horário local -03:00)
srv-rh01_security.csv       eventos Security do SRV-RH01 exportados pelo coletor (UTC)
folha_app.log               log da aplicação de folha (UTC)
ntp_status_srv-rh01.txt     saída de comandos de hora executados no SRV-RH01
cmdb_srv-rh01.txt           ficha do ativo na CMDB
```

```
escala_plantao.csv          escala de plantão e mudanças aprovadas do RH

TAREFAS
1. Converta todos os horários relevantes para UTC.
2. Identifique a fonte com relógio errado e calcule o desvio.
3. Monte a timeline do acesso, do login na VPN até o fim da sessão.
4. Encontre o evento duplicado e explique por que ele não é um segundo acesso.
5. Classifique o alerta (VP, FP ou BP) e justifique com evidências.
6. Escreva duas recomendações.
```

alerta_siem.json *Alerta gerado pelo SIEM*

```
{

  "alert_id": "SIEM-2026-118204",

  "rule": "Acesso RDP fora do horário a servidor de RH",

  "severity": "Medium",

  "alert_time": "2026-11-07T02:24:30Z",

  "first_event_time": "2026-11-07T02:21:05Z",

  "host": "SRV-RH01",

  "user": "CORP\\carla.mendes",

  "source_ip": "10.200.1.37",

  "logic": "EventID 4624 AND LogonType 10 AND host in grupo_RH AND hora_local fora de 07:00-20:00"

}
```

vpn_gateway.log *Concentrador VPN (UTC)*

```
2026-11-07T01:48:12Z vpn-gw01 event=auth_success user=joao.pereira src_ip=203.0.113.88 src_country=BR
assigned_ip=10.200.1.21 mfa=push_approved mfa_attempts=1 device=NB-TI-014 device_managed=true

2026-11-07T01:48:13Z vpn-gw01 event=tunnel_up user=joao.pereira assigned_ip=10.200.1.21

2026-11-07T01:59:30Z vpn-gw01 event=auth_failure user=admin src_ip=203.0.113.200 reason=unknown_user

2026-11-07T01:59:31Z vpn-gw01 event=auth_failure user=teste src_ip=203.0.113.200 reason=unknown_user

2026-11-07T02:03:51Z vpn-gw01 event=auth_failure user=carla.mendes src_ip=203.0.113.45 src_country=BR
reason=bad_password

2026-11-07T02:05:40Z vpn-gw01 event=auth_success user=carla.mendes src_ip=203.0.113.45 src_country=BR
assigned_ip=10.200.1.37 mfa=push_approved mfa_attempts=1 device=NB-RH-007 device_managed=true

2026-11-07T02:05:41Z vpn-gw01 event=tunnel_up user=carla.mendes assigned_ip=10.200.1.37

2026-11-07T02:31:02Z vpn-gw01 event=tunnel_down user=joao.pereira assigned_ip=10.200.1.21 duration=2569s
bytes_in=8812031 bytes_out=1203311

2026-11-07T03:02:10Z vpn-gw01 event=tunnel_down user=carla.mendes assigned_ip=10.200.1.37 duration=3389s
bytes_in=21455120 bytes_out=3302114
```

`firewall_interno.log` *Firewall interno (horário local, -03:00)*

```
date=2026-11-06 time=22:50:11 tz="-0300" devname="FW-CORE01" action="allow" policyid=40 policyname="VPN-ADM-TI" srcip=10.200.1.21 srcport=50112 dstip=10.20.0.30 dstport=22 proto=6 service="SSH" duration=1802 sentbyte=310221 rcvdbyte=1120331

date=2026-11-06 time=23:00:03 tz="-0300" devname="FW-CORE01" action="deny" policyid=0 policyname="implicit-deny" srcip=10.200.1.21 srcport=50190 dstip=10.20.0.15 dstport=3389 proto=6 service="RDP" sentbyte=60 rcvdbyte=0

date=2026-11-06 time=23:10:02 tz="-0300" devname="FW-CORE01" action="allow" policyid=52 policyname="VPN-ADM-RH" srcip=10.200.1.37 srcport=52811 dstip=10.20.0.15 dstport=3389 proto=6 service="RDP" duration=3096 sentbyte=2810331 rcvdbyte=19022871

date=2026-11-06 time=23:10:02 tz="-0300" devname="FW-CORE01" action="allow" policyid=52 policyname="VPN-ADM-RH" srcip=10.200.1.37 srcport=52812 dstip=10.20.0.15 dstport=3389 proto=17 service="RDP-UDP" duration=3090 sentbyte=402114 rcvdbyte=2101330

date=2026-11-06 time=23:12:40 tz="-0300" devname="FW-CORE01" action="allow" policyid=12 policyname="SRV-TO-DNS" srcip=10.20.0.15 srcport=61022 dstip=10.20.0.5 dstport=53 proto=17 service="DNS" sentbyte=74 rcvdbyte=90
```

`srv-rh01_security.csv` *Eventos Security do SRV-RH01 (exportados em UTC)*

```
TimeCreatedUTC,EventID,Computer,TargetUserName,LogonType,IpAddress,TargetLogonId,RecordId,CollectorId

2026-11-07T02:21:05.412Z,4624,SRV-RH01,carla.mendes,10,10.200.1.37,0x5A3F21,884120,coletor-a

2026-11-07T02:21:05.412Z,4624,SRV-RH01,carla.mendes,10,10.200.1.37,0x5A3F21,884120,coletor-b

2026-11-07T02:21:05.430Z,4672,SRV-RH01,carla.mendes,,,0x5A3F21,884121,coletor-a

2026-11-07T03:12:40.008Z,4634,SRV-RH01,carla.mendes,10,,0x5A3F21,884377,coletor-a
```

`folha_app.log` *Aplicação da folha (UTC)*

```
2026-11-07T02:12:24Z app-folha01 INFO user=carla.mendes action=login origem=SRV-RH01 resultado=ok

2026-11-07T02:12:58Z app-folha01 INFO user=carla.mendes action=fechamento_iniciado competencia=2026-10 lote=F-2026-10-01

2026-11-07T02:58:31Z app-folha01 INFO user=carla.mendes action=fechamento_concluido competencia=2026-10 lote=F-2026-10-01 registros=812

2026-11-07T02:59:02Z app-folha01 INFO user=carla.mendes action=logout
```

`ntp_status_srv-rh01.txt` *Comandos de hora executados no SRV-RH01*

```
Coletado em: 2026-11-07, pelo time de infraestrutura, a pedido do SOC.

C:\> w32tm /query /status
Leap Indicator: 3(not synchronized)
Stratum: 0 (unspecified)
Last Successful Sync Time: 10/10/2026 08:14:03
Source: Local CMOS Clock
Poll Interval: 10 (1024s)

C:\> w32tm /stripchart /computer:dc01.corp.local /samples:3 /dataonly
Tracking dc01.corp.local [10.20.0.5:123].
Collecting 3 samples.
The current time is 07/11/2026 06:21:14.
06:21:14, -660.4021337s
06:21:16, -660.4019870s
06:21:18, -660.4021104s
```

```
Observação do analista de infraestrutura: o offset negativo indica que o DC01 está
660 segundos atrás do relógio deste servidor, ou seja, o SRV-RH01 está adiantado.
```

`cmdb_srv-rh01.txt` *Ficha do ativo na CMDB*

```
Ativo: SRV-RH01
Função: servidor de aplicação e arquivos do RH (folha de pagamento)
Criticidade: Alta (dados pessoais e salariais)
Owner: Gerência de RH (Patrícia Nunes); custódia técnica: Infraestrutura
IP: 10.20.0.15 (VLAN 20, servidores)
Acesso administrativo permitido: RDP somente a partir da VPN, grupo GRP-VPN-RH (regra VPN-ADM-RH)
Fuso configurado: America/Sao_Paulo
Fonte de hora esperada: hierarquia do domínio (DC01)
```

`escala_plantao.csv` *Escala de plantão e mudanças aprovadas*

```
data,colaborador,area,janela_local,mudanca,descricao

2026-11-06,carla.mendes,RH,22:00-02:00 (-03:00),CHG-2211,Fechamento da folha de outubro (competência 2026-
10)

2026-11-06,joao.pereira,TI,22:00-06:00 (-03:00),CHG-2208,Manutenção de servidores Linux
```

Lab 5.5: O mesmo caso pela linha de comando

Item	Descrição
Objetivo	Responder partes do Lab 5.4 com grep, awk, cut e date, como você faria com arquivos exportados.
Duração	30 minutos
Pré-requisitos	Linux ou WSL; pasta `Lab_5.4_timeline_rh` descompactada. Em PowerShell, use os equivalentes da seção 5.12.

#	Pergunta	Comando
1	Quantos logins bem-sucedidos há na VPN?	`grep -c 'event=auth_success' vpn_gateway.log`
2	Qual a sequência de eventos da carla na VPN?	`grep 'user=carla.mendes' vpn_gateway.log | cut -d' ' -f1,3`
3	Quais acessos à porta 3389 e com que resultado?	`grep 'dstport=3389' firewall_interno.log | grep -oE 'time=[0-9:]+|action="[a-z]+"|srcip=[0-9.]+' | paste - - -`
4	Algum RecordId repetido no CSV do Windows?	`awk -F, 'NR>1{print $8}' srv-rh01_security.csv | sort | uniq -d`
5	Quais eventos do Windows e com qual Logon ID?	`awk -F, 'NR>1{print $1, $2, $4, $7}' srv-rh01_security.csv`
6	Qual horário o alerta usou?	`grep -o '"first_event_time": "[^"]*"' alerta_siem.json`
7	Converter o firewall para UTC e corrigir o drift do Windows	`date -u -d '2026-11-06T23:10:02-03:00' +%FT%TZ` e `date -u -d '2026-11-07T02:21:05Z - 660 seconds' +%FT%TZ`

#	Pergunta	Comando
8	Quais ações aparecem no log da aplicação?	`grep -oE 'action=[a-z_]+' folha_app.log`

Antes de começar, registre o hash dos arquivos com `sha256sum *` e cole no seu relatório. As saídas esperadas estão no gabarito.

Lab 5.6: Do e-mail ao endpoint

Item	Descrição
Objetivo	Seguir uma campanha de phishing por cinco fontes e decidir o que escalar.
Duração	60 minutos
Pré-requisitos	Seções 5.6, 5.7 e 5.9. Pasta `Lab_5.6_phishing` do anexo. Opcional: `jq`.

#	Tarefa
1	Quantas pessoas receberam a mensagem e qual foi o destino de cada cópia?
2	Quem consultou o domínio e quem clicou no link?
3	Quem baixou o arquivo? Ele foi executado?
4	Monte a timeline em UTC.
5	Classifique o caso e diga se e por que escalaria.
6	Liste as ações recomendadas, separando o que já foi feito do que falta.

Comandos úteis (opcionais):

```
jq -r 'select(.url|test("fatura-pagamentos")) | [.time,.user,.action,.status,.url] | @tsv'
proxy.log
jq -r 'select(.query=="fatura-pagamentos.example") | [.ts,.client] | @tsv' dns.json
jq -c 'select(.event=="Detection") | {timestamp, device, detection}' edr.json
awk -F, 'NR>1{print $10}' email_trace.csv | sort | uniq -c
```

Arquivos do laboratório (conteúdo integral):

`LEIA-ME.txt` *Cenário e tarefas*

```
LAB 5.6 - DO E-MAIL AO ENDPOINT
Todos os dados são FICTÍCIOS. Domínios .example e IPs 203.0.113.0/24 são reservados
para documentação. Nomes de pessoas são inventados.


CENÁRIO
Quinta-feira, 05/11/2026, manhã. Um usuário reportou um e-mail estranho com o assunto
"Fatura em atraso: 2º aviso". O SOC precisa responder: quem recebeu, quem clicou,
quem baixou, se algo executou e qual o próximo passo.


ARQUIVOS
email_trace.csv       rastreamento de mensagens (UTC)
dns.json              consultas ao resolver interno (UTC), um evento por linha
proxy.log             proxy web (horário local -03:00), um evento JSON por linha
edr.json              eventos do EDR (UTC), um evento por linha
dhcp.log              concessões DHCP (horário local -03:00)
usuarios.csv          usuários, áreas e estações
```

```
TAREFAS
1. Quantas pessoas receberam a mensagem e qual foi o destino de cada cópia?
2. Quem consultou o domínio e quem clicou no link?
3. Quem baixou o arquivo? Ele foi executado?
4. Monte a timeline em UTC.
5. Classifique o caso e diga se e por que escalaria.
6. Liste as ações recomendadas, separando o que já foi feito do que falta.
```

`email_trace.csv` *Rastreamento de mensagens (UTC)*

```
Received,MessageId,SenderAddress,RecipientAddress,Subject,FromIP,SPF,DKIM,DMARC,Status

2026-11-05T13:02:41Z,<8812@mail.fatura-pagamentos.example>,cobranca@fatura-
pagamentos.example,ana.lima@empresa.example,"Fatura em atraso: 2º
aviso",203.0.113.77,fail,none,fail,Delivered

2026-11-05T13:02:41Z,<8812@mail.fatura-pagamentos.example>,cobranca@fatura-
pagamentos.example,bruno.costa@empresa.example,"Fatura em atraso: 2º
aviso",203.0.113.77,fail,none,fail,Delivered

2026-11-05T13:02:42Z,<8812@mail.fatura-pagamentos.example>,cobranca@fatura-
pagamentos.example,carla.mendes@empresa.example,"Fatura em atraso: 2º
aviso",203.0.113.77,fail,none,fail,Delivered

2026-11-05T13:02:42Z,<8812@mail.fatura-pagamentos.example>,cobranca@fatura-
pagamentos.example,diego.rocha@empresa.example,"Fatura em atraso: 2º
aviso",203.0.113.77,fail,none,fail,Junk

2026-11-05T13:40:05Z,<8812@mail.fatura-pagamentos.example>,cobranca@fatura-
pagamentos.example,ana.lima@empresa.example,"Fatura em atraso: 2º
aviso",203.0.113.77,fail,none,fail,RemovedByAdmin

2026-11-05T13:40:05Z,<8812@mail.fatura-pagamentos.example>,cobranca@fatura-
pagamentos.example,bruno.costa@empresa.example,"Fatura em atraso: 2º
aviso",203.0.113.77,fail,none,fail,RemovedByAdmin

2026-11-05T13:40:06Z,<8812@mail.fatura-pagamentos.example>,cobranca@fatura-
pagamentos.example,carla.mendes@empresa.example,"Fatura em atraso: 2º
aviso",203.0.113.77,fail,none,fail,RemovedByAdmin

2026-11-05T13:40:06Z,<8812@mail.fatura-pagamentos.example>,cobranca@fatura-
pagamentos.example,diego.rocha@empresa.example,"Fatura em atraso: 2º
aviso",203.0.113.77,fail,none,fail,RemovedByAdmin
```

`dns.json` *Resolver interno (UTC)*

```
{"ts":"2026-11-
05T13:09:12.401Z","client":"10.10.0.87","query":"portal.empresa.example","qtype":"A","rcode":"NOERROR","answers":["203.0.

{"ts":"2026-11-05T13:14:21.802Z","client":"10.10.0.87","query":"fatura-
pagamentos.example","qtype":"A","rcode":"NOERROR","answers":["203.0.113.78"]}

{"ts":"2026-11-05T13:20:05.117Z","client":"10.10.0.112","query":"fatura-
pagamentos.example","qtype":"A","rcode":"NOERROR","answers":["203.0.113.78"]}

{"ts":"2026-11-
05T13:21:40.330Z","client":"10.10.0.140","query":"intranet.empresa.example","qtype":"A","rcode":"NOERROR","answers":["10.
```

`proxy.log` *Proxy web (horário local, -03:00)*

```
{"time":"2026-11-05T10:09:12-
03:00","user":"ana.lima","src":"10.10.0.87","method":"GET","url":"https://portal.empresa.example/","category":"Business",
```

```
{"time":"2026-11-05T10:14:22-03:00","user":"ana.lima","src":"10.10.0.87","method":"GET","url":"https://fatura-pagamentos.
Domains","action":"allowed","status":302,"bytes_in":512,"content_type":"text/html"}

{"time":"2026-11-05T10:14:23-03:00","user":"ana.lima","src":"10.10.0.87","method":"GET","url":"https://fatura-pagamentos.
Domains","action":"allowed","status":200,"bytes_in":412311,"content_type":"application/zip"}

{"time":"2026-11-05T10:20:06-03:00","user":"bruno.costa","src":"10.10.0.112","method":"GET","url":"https://fatura-
pagamentos.example/boleto?id=8812","category":"Phishing","action":"blocked","status":403,"bytes_in":0,"content_type":"tex
```


`edr.json` *EDR (UTC)*


```
{"timestamp":"2026-11-05T13:14:24.051Z","device":"NB-FIN-042","user":"CORP\\ana.lima","event":"FileCreated","file":{"path

{"timestamp":"2026-11-05T13:15:02.880Z","device":"NB-FIN-042","user":"CORP\\ana.lima","event":"FileCreated","file":{"path

{"timestamp":"2026-11-05T13:15:04.112Z","device":"NB-FIN-
042","user":"CORP\\ana.lima","event":"Detection","detection":{"name":"Suspicious.Generic","severity":"High","action":"Qua
```


`dhcp.log` *Concessões DHCP (horário local, data MM/DD/AA)*

```
ID,Date,Time,Description,IP Address,Host Name,MAC Address

11,11/05/26,07:58:10,Renew,10.10.0.87,NB-FIN-042.corp.local,3C5282112233

11,11/05/26,08:02:44,Renew,10.10.0.112,NB-FIN-051.corp.local,3C5282515151

10,11/05/26,08:30:19,Assign,10.10.0.140,NB-RH-007.corp.local,3C52827A0007
```

`usuarios.csv` *Usuários, áreas e estações*

```
usuario,area,estacao_principal,regime

ana.lima,Financeiro,NB-FIN-042,presencial

bruno.costa,Financeiro,NB-FIN-051,presencial

carla.mendes,RH,NB-RH-007,híbrido (home office às quintas, VPN split tunnel)

diego.rocha,Comercial,NB-COM-019,presencial
```

Lab 5.7: Quando o log mente sem querer

Item	Descrição
Objetivo	Encontrar problemas de qualidade num export de firewall e responder ao gestor com honestidade.
Duração	40 minutos
Pré-requisitos	Seção 5.8. Pasta `Lab_5.7_qualidade` do anexo.

#	Tarefa
1	Liste todos os problemas de qualidade que encontrar, citando a linha ou o horário.
2	Para cada problema, diga o impacto na detecção e na investigação.
3	Responda ao gestor em até cinco linhas: a madrugada foi tranquila?

#	Tarefa
4	Diga a quem você acionaria e o que pediria.

Arquivos do laboratório (conteúdo integral):

`LEIA-ME.txt` *Cenário e tarefas*

```
LAB 5.7 - QUANDO O LOG MENTE SEM QUERER
Todos os dados são FICTÍCIOS.

CENÁRIO
Sexta-feira, 06/11/2026. O SIEM não gerou nenhum alerta do firewall de borda durante a
madrugada de 05/11. O gestor pergunta: "então a madrugada foi tranquila?". Antes de
responder, você exportou os eventos do firewall e o painel de saúde da fonte.

ARQUIVOS
firewall_export.csv   eventos do FW-BORDA01 exportados do SIEM (event_time e ingest_time em -03:00)
siem_saude.csv        eventos recebidos por hora da fonte FW-BORDA01
mudancas.txt          mudanças registradas para o período

TAREFAS
1. Liste todos os problemas de qualidade que encontrar, citando a linha ou o horário.
2. Para cada problema, diga o impacto na detecção e na investigação.
3. Responda ao gestor em até cinco linhas: a madrugada foi tranquila?
4. Diga a quem você acionaria e o que pediria.
```

`firewall_export.csv` *Eventos do FW-BORDA01 (event_time e ingest_time em -03:00)*

```
linha,event_time,ingest_time,device,src_ip,src_port,dst_ip,dst_port,action,user

1,2026-11-05T00:58:10-03:00,2026-11-05T00:58:12-03:00,FW-
BORDA01,10.10.0.87,51022,203.0.113.80,443,allow,ana.lima

2,2026-11-05T01:05:44-03:00,2026-11-05T01:05:46-03:00,FW-
BORDA01,203.0.113.200,40122,198.51.100.20,3389,deny,

3,2026-11-05T01:05:44-03:00,2026-11-05T01:05:46-03:00,FW-
BORDA01,203.0.113.200,40122,198.51.100.20,3389,deny,

4,2026-11-05T01:12:03-03:00,2026-11-05T01:12:05-03:00,FW-
BORDA01,10.10.0.140,52114,203.0.113.44,443,allow,carla.mendes

5,2026-11-05T03:47:12-03:00,2026-11-05T03:47:15-03:00,FW-
BORDA01,0.0.0.0,0,203.0.113.80,443,allow,10.10.0.87

6,2026-11-05T03:51:20-03:00,2026-11-05T03:51:22-03:00,FW-BORDA01,0.0.0.0,0,198.51.100.2

7,2026-11-05T04:02:31-03:00,2026-11-05T04:02:33-03:00,FW-
BORDA01,0.0.0.0,0,198.51.100.20,3389,deny,203.0.113.200

8,2026-11-05T05:10:09-03:00,2026-11-05T05:10:11-03:00,FW-
BORDA01,0.0.0.0,0,203.0.113.66,8443,allow,10.10.0.91

9,2026-11-05T08:00:14-03:00,2026-11-05T08:41:52-03:00,FW-
BORDA01,10.10.0.87,51990,203.0.113.80,443,allow,ana.lima

10,2026-11-05T08:00:20-03:00,2026-11-05T08:42:03-03:00,FW-
BORDA01,10.10.0.112,50211,203.0.113.80,443,allow,bruno.costa
```

`siem_saude.csv` *Eventos recebidos por hora*

```
fonte,hora_local,eventos_recebidos
```

```
FW-BORDA01,2026-11-05 00h,1212

FW-BORDA01,2026-11-05 01h,208

FW-BORDA01,2026-11-05 02h,0

FW-BORDA01,2026-11-05 03h,96

FW-BORDA01,2026-11-05 04h,1174

FW-BORDA01,2026-11-05 05h,1190

FW-BORDA01,2026-11-05 06h,1305

FW-BORDA01,2026-11-05 07h,1288

FW-BORDA01,2026-11-05 08h,0

FW-BORDA01,2026-11-05 09h,2710
```

`mudancas.txt` *Mudanças registradas*

```
CHG-2230  Atualização de firmware do FW-BORDA01
Janela aprovada: 05/11/2026 01:00 a 04:00 (-03:00)
Responsável: equipe de redes
Observação: "pode haver indisponibilidade de log durante o reboot"
Comunicado ao SOC: não encontrado.
```

Erros comuns

Erro	Por que é um problema	Como evitar
Escrever horário sem fuso no ticket	Ninguém consegue reproduzir nem correlacionar.	ISO 8601 com fuso, ou UTC declarado.
Comparar fontes sem normalizar o tempo	Sequência errada, conclusões erradas.	Converter tudo antes de ordenar.
Confiar no horário da tela	O console pode estar em outro fuso.	Conferir a configuração de exibição.
Tratar duplicata como dois eventos	Infla contagens e cria "segundo acesso" fantasma.	Comparar IDs de registro e coletor.
Concluir "não aconteceu" por busca vazia	Pode ser lacuna, parser ou retenção.	Verificar saúde da fonte e evento bruto.
Ligar eventos só pela proximidade de horário	Coincidência vira causalidade.	Usar pivôs reais (sessão, usuário, IP atribuído).
Ler o resumo do alerta e não o campo	O resumo é interpretação da regra.	Abrir o evento e ler os campos.
Alterar o arquivo de evidência	Quebra a integridade.	Trabalhar em cópia e registrar hash.

Falsos positivos comuns ligados a logs

Alerta	Causa no próprio log	Como confirmar
Atividade "fora do horário"	Fuso errado no parser ou relógio da fonte com drift.	Comparar com fonte sincronizada; verificar fuso do parser.
Pico de eventos / brute force	Duplicação por dois coletores.	IDs de registro iguais.
"Novo IP de origem" em massa	Parser quebrado gravando campo errado.	Evento bruto.
Impossible travel	Base de geolocalização desatualizada; VPN com saída em outro país.	ASN e saída da VPN.
Regra de ausência ("fonte parou")	Atraso de ingestão, não parada real.	Comparar event time e ingestion time.
Eventos "do futuro"	Relógio da fonte adiantado.	Comandos de hora no host.

Exercícios

1. Converta `2026-11-06T23:10:02-03:00` para UTC.
2. Converta o epoch `1793970131` para UTC e para horário de Brasília.
3. Você recebeu a linha `Nov  6 10:02:11 web01 sshd[2211]: Accepted publickey for deploy from 10.99.0.10`. O que precisa saber para colocá-la numa timeline em UTC?
4. O log do IIS mostra uma requisição às 16:02:11 e o firewall mostra a mesma conexão às 13:02:11 -03:00. Há contradição?
5. Qual a diferença entre event time e ingestion time? Que problema surge se uma regra usar só o ingestion time com janela de 5 minutos?
6. Dois eventos 4624 idênticos, com o mesmo RecordId, chegaram por coletores diferentes. Quantos logons aconteceram?
7. Uma busca pelo IP 10.10.0.66 no campo normalizado não retorna nada do firewall, embora ele envie logs. Cite três hipóteses.
8. Que pivô liga um login de VPN a um logon no Windows? E um logon no Windows às ações seguintes na mesma sessão?
9. Um parceiro diz: "seu IP atacou nosso servidor ontem à noite". Que campos e informações você pede antes de investigar?
10. Após uma atualização do firewall, metade dos eventos chega com `src_ip=0.0.0.0`. Como interpretar?
11. Escreva em ISO 8601 UTC: "6 de novembro de 2026, 22:15, horário de Brasília".
12. Uma consulta DNS e uma conexão no firewall aconteceram com 2 segundos de diferença. Isso prova que a conexão foi causada pela consulta?
13. Num 4625, qual a diferença de triagem entre o Sub Status `0xC000006A` e `0xC0000064`?
14. No Entra ID, um mesmo IP gerou `ResultType` 50126 para 40 contas diferentes em 3 minutos. Que padrão é esse e qual o próximo passo?
15. No log de DHCP do Windows, o que significam os IDs 10, 11 e 12? Por que a data `11/06/26` exige cuidado?

16. Na linha `sudo: deploy : TTY=pts/0 ; PWD=/home/deploy ; USER=root ; COMMAND=/usr/bin/systemctl restart nginx`, responda: quem, como quem, o quê e de onde.
17. Qual fonte responde "qual processo abriu esta conexão"? E qual responde "qual URL o usuário acessou"?
18. Reescreva como evidência de ticket: "o firewall liberou o RDP da carla às 23h".
19. Um painel mostra 0 eventos de uma fonte às 08h e o dobro do normal às 09h. Cite duas hipóteses e como testá-las.
20. Por que buscar no evento bruto quando a busca pelo campo normalizado não retorna nada? Dê um exemplo.

Perguntas de entrevista

P: O que é um log e por que ele é importante para o SOC?

Resposta fraca	Resposta boa
"É um arquivo de registro."	É o registro de eventos de uma fonte: logins, conexões, processos, consultas. O SOC não vê o ataque acontecendo; vê os rastros registrados. Por isso preciso saber ler campos, horários e entender quando o log está incompleto.

O que está sendo avaliado: Visão de que log é evidência, com limitações.

P: Quais campos você olha primeiro num evento?

Resposta fraca	Resposta boa
"A mensagem."	Timestamp com fuso, host que registrou, usuário, origem e destino com portas, ação ou resultado, e um identificador de sessão. Depois, conforme a fonte: processo, processo pai, hash, URL, domínio e user-agent.

O que está sendo avaliado: Método de leitura.

P: Por que usar UTC?

Resposta fraca	Resposta boa
"Porque é o padrão."	Porque fontes diferentes registram em fusos diferentes, e só com uma referência única a sequência fica correta. Uso ISO 8601 com fuso ou UTC declarado no ticket e registro o fuso original de cada fonte.

O que está sendo avaliado: Entendimento do problema real.

P: O que é clock drift e como você perceberia?

Resposta fraca	Resposta boa
"Não sei."	É o desvio do relógio de uma máquina por falha de sincronização. Percebo quando o mesmo fato aparece com horários incompatíveis em fontes diferentes, ou sequências impossíveis. Confirmo com comandos de hora no host e corrijo a timeline registrando o desvio.

O que está sendo avaliado: Atenção a detalhes e capacidade de verificação.

P: Qual a diferença entre event time e ingestion time?

Resposta fraca	Resposta boa
"São a mesma coisa."	Event time é quando aconteceu na fonte; ingestion time é quando chegou ao SIEM. A diferença mostra atraso do pipeline, e regras mal configuradas podem perder eventos atrasados. Na timeline uso o event time corrigido.

O que está sendo avaliado: Conhecimento de pipeline.

P: O que é normalização?

Resposta fraca	Resposta boa
"Deixar os logs bonitos."	É traduzir os campos de cada fonte para um esquema comum, como ECS, ASIM ou CIM, para que um IP ou usuário seja buscado em todas as fontes de uma vez. Se o parser quebra, o campo normalizado fica vazio e preciso olhar o evento bruto.

O que está sendo avaliado: Entendimento técnico e prático.

P: Como você monta uma timeline?

Resposta fraca	Resposta boa
"Coloco os alertas em ordem."	Defino a janela, listo as fontes e confirmo que estavam enviando, normalizo o tempo, uso pivôs como usuário, IP atribuído e ID de sessão, ordeno com a evidência de cada linha e separo fato de inferência, registrando as lacunas.

O que está sendo avaliado: Raciocínio estruturado.

P: Sua busca não retornou nada. O que isso significa?

Resposta fraca	Resposta boa
"Que não aconteceu."	Que não encontrei nas fontes consultadas. Antes de concluir, verifico se a fonte estava enviando no período, se há atraso, se o parser está preenchendo o campo, se a retenção cobre a data e se estou buscando no campo certo.

O que está sendo avaliado: Honestidade sobre limitações.

P: Dois eventos com 2 segundos de diferença estão relacionados?

Resposta fraca	Resposta boa
"Sim, aconteceram juntos."	Não necessariamente. Proximidade não é causalidade. Procuro um pivô que una os dois, como mesma sessão, usuário ou IP atribuído, e verifico se a sequência faz sentido técnico.

O que está sendo avaliado: Rigor na correlação.

P: Como você documenta horários num ticket?

Resposta fraca	Resposta boa
"Coloco a hora que aparece."	Em ISO 8601 com fuso ou em UTC declarado, citando a fonte e o fuso original de cada uma, e registrando correções de drift aplicadas.

O que está sendo avaliado: Qualidade de documentação.

P: Você recebeu um log sem fuso horário. Como trata?

Resposta fraca	Resposta boa
"Considero que é horário de Brasília."	Descubro o fuso pela configuração do host e do coletor, comparo um evento conhecido com uma fonte sincronizada e registro a premissa no ticket. Se não der para confirmar, deixo explícita a incerteza.

O que está sendo avaliado: Rigor e honestidade sobre premissas.

P: O que são syslog e CEF?

Resposta fraca	Resposta boa
"São tipos de log."	Syslog é um protocolo e formato de envio de logs pela rede; o tradicional (RFC 3164) não tem ano nem fuso, o mais novo (RFC 5424) tem horário completo e campos estruturados. CEF é um formato com cabeçalho fixo e pares chave=valor, comum em appliances de segurança enviando a SIEMs.

O que está sendo avaliado: Conhecimento de formatos.

P: Como você prova que dois eventos são duplicados?

Resposta fraca	Resposta boa
"São iguais."	Comparo o identificador do registro na fonte, como o RecordId no Windows, e todos os campos. Se forem idênticos e só mudar o coletor, é o mesmo evento enviado duas vezes. Confirmo com outra fonte que viu a atividade só uma vez, como o firewall.

O que está sendo avaliado: Raciocínio de evidência.

P: Que logs você usa para investigar um phishing?

Resposta fraca	Resposta boa
"O do e-mail."	Rastreamento de mensagens para saber quem recebeu, DNS e proxy para saber quem clicou e baixou, EDR para saber se algo executou, DHCP para ligar IP a máquina e IdP de nuvem se houver suspeita de credencial digitada.

O que está sendo avaliado: Visão de cadeia de evidências.

P: O que é enriquecimento e qual o risco dele?

Resposta fraca	Resposta boa
"É deixar o log mais completo."	É somar contexto ao evento: geolocalização, criticidade do ativo, área do usuário, reputação do IP, mudança aprovada. Ajuda a priorizar, mas pode errar, como GeoIP desatualizado ou CMDB velha, então confirmo antes de usar como conclusão.

O que está sendo avaliado: Senso crítico sobre ferramentas.

Checklist de domínio

- ☐ Explico os 17 campos essenciais, suas armadilhas e a pergunta que cada um responde.
- ☐ Converto entre UTC, horário local e epoch sem errar.
- ☐ Diferencio event time, ingestion time e display time.
- ☐ Reconheço e confirmo clock drift, e sei registrar a correção.
- ☐ Reconheço syslog, CEF, key=value, JSON, CSV/W3C e XML/EVTX.
- ☐ Explico normalização e o efeito de um parser quebrado.
- ☐ Leio logs de Windows, Linux, firewall, proxy, DNS, VPN, EDR, WAF, e-mail e AD.
- ☐ Monto timeline com pivôs e separo fato de inferência.
- ☐ Identifico lacunas, duplicatas, truncamento e problemas de retenção.
- ☐ Leio códigos de falha do 4625 e ResultType do Entra ID.
- ☐ Sei qual log responde a cada pergunta comum de investigação.
- ☐ Cito evidências no ticket com horário UTC, fonte, fato, forma de achar e limitação.
- ☐ Concluí os Labs 5.1 a 5.7.

Resumo do módulo

- Log é evidência com limitações: só existe o que foi registrado, chegou e foi entendido.
- Leia o **campo**, não o título do alerta. Cada campo responde a uma pergunta: quando, onde, quem, de onde, para onde, o quê, por quê e como ligar ao resto.
- **Tempo** é o campo que mais engana: use UTC ou ISO 8601 com fuso, diferencie event time de ingestion time e corrija clock drift.
- Formatos variam; **normalização** permite buscar em todas as fontes, e parser quebrado cega a busca.
- **Correlação** usa pivôs reais (sessão, usuário, IP atribuído, hash), não apenas horários próximos.
- Antes de concluir "não aconteceu", confirme que a fonte estava viva, em dia, completa e dentro da retenção.

Cheat sheet de logs

Tema	Lembrete
Tempo	Escreva em ISO 8601 com fuso ou UTC (`Z`). Brasília = UTC-3. Para UTC, some 3 h; cuidado com a virada do dia.
Epoch	10 dígitos = segundos; 13 dígitos = milissegundos. Sempre UTC. `date -u -d @EPOCH`.

Tema	Lembrete
Três horários	Event time (timeline), ingestion time (saúde do pipeline), display time (configuração da tela).
Drift	Mesmo fato com minutos de diferença entre fontes. Confirme com `w32tm` ou `timedatectl` / `chronyc`.
Sem fuso	Syslog RFC 3164, IIS (UTC implícito), DHCP do Windows (local, data MM/DD/AA).
Formatos	Syslog 3164/5424, CEF, key=value, JSON/NDJSON, CSV/W3C, XML/EVTX.
Pivôs	IP + janela, usuário, hostname, Logon ID, session ID, ProcessGuid, hash, domínio, MessageId.
Qualidade	Lacuna, atraso, fuso errado, drift, duplicata, parser quebrado, truncado, retenção.
4625	`0xC000006A` senha errada; `0xC0000064` usuário inexistente; `0xC0000234` bloqueada; `0xC0000072` desabilitada.
Entra ID	`0` sucesso; `50126` senha inválida; `50053` bloqueada; `50074` MFA exigido; `500121` falha no MFA.
Ticket	[UTC] fonte (fuso original) | fato | como achar | interpretação | limitação.

Respostas comentadas dos exercícios

Exercício 1. `2026-11-07T02:10:02Z`. Somam-se 3 horas e a data vira o dia seguinte.

Exercício 2. `2026-11-06T13:02:11Z` (UTC), que corresponde a `2026-11-06T10:02:11-03:00` em Brasília. Confira com `date -u -d @1793970131`.

Exercício 3. O **ano** (a linha não tem) e o **fuso** do host (a linha não tem), além de saber se o coletor reinterpretou o horário ao receber. Com o host em America/Sao_Paulo e ano 2026, a linha corresponde a `2026-11-06T13:02:11Z`. Registre essa premissa no ticket.

Exercício 4. Não. O IIS registra em **UTC por padrão**: 16:02:11 UTC é exatamente 13:02:11 em -03:00. É o mesmo instante.

Exercício 5. Event time é quando aconteceu na fonte; ingestion time é quando chegou ao SIEM. Se a regra olha só o ingestion time numa janela curta, eventos com atraso podem cair fora da janela certa, ser contados no período errado ou gerar alertas com horário que não bate com a realidade. Na timeline, use sempre o event time (corrigido).

Exercício 6. Um. Mesmo RecordId e mesmos campos indicam o mesmo registro enviado por dois coletores. É problema de pipeline, não segundo logon.

Exercício 7. Parser quebrado ou campo com outro nome após atualização; fonte sem eventos no período (lacuna) ou com atraso; período fora da retenção; filtro de índice ou de tempo errado na consulta; o IP estava traduzido por NAT. Verifique o evento bruto e a saúde da fonte.

Exercício 8. VPN → Windows: o **IP atribuído pela VPN** (que aparece como origem no logon) mais a janela de tempo e o usuário. Windows → ações seguintes: o **Logon ID** da sessão (e, para processos, o ProcessGuid ou PID com horário).

Exercício 9. IP público, **porta de origem**, **horário exato com fuso**, IP e porta de destino, protocolo, e se possível o log original. Sem porta e horário preciso, o NAT impede atribuir a um host interno (Módulo 1).

Exercício 10. Muito provavelmente o **parser quebrou** com o novo formato de log. Os eventos existem, mas o campo de origem não está sendo extraído. Consequência: regras que dependem do IP de origem ficam cegas. Verificar o evento bruto e acionar o responsável pelo SIEM.

Exercício 11. `2026-11-07T01:15:00Z`.

Exercício 13. `0xC000006A`: a conta existe e a senha está errada; investigue se é erro do próprio usuário ou alguém tentando. `0xC0000064`: o usuário nem existe; em volume, indica enumeração ou lista genérica de nomes, típico de tentativa automatizada.

Exercício 14. Password spraying: poucas tentativas por conta, muitas contas, uma origem. Próximo passo: verificar se alguma conta teve sucesso (ResultType 0) a partir desse IP ou em seguida, enriquecer o IP e seguir o Playbook (Módulo 17).

Exercício 15. 10 = nova concessão, 11 = renovação, 12 = liberação. A data está no formato americano MM/DD/AA: `11/06/26` é 6 de novembro de 2026, e não 11 de junho.

Exercício 16. Quem: o usuário `deploy`. Como quem: `root`. O quê: reiniciar o serviço nginx. De onde: o terminal `pts/0`, uma sessão remota (normalmente SSH). Falta: ano e fuso, que não estão na linha.

Exercício 17. Processo: **EDR** (ou Sysmon Event ID 3). URL: **proxy/SWG** (com inspeção TLS para a URL completa em HTTPS).

Exercício 18. "2026-11-07T02:10:02Z (23:10:02 -03:00), FW-CORE01: allow RDP de 10.200.1.37:52811 para 10.20.0.15:3389 (SRV-RH01), regra VPN-ADM-RH, duração 3096 s. 10.200.1.37 era o IP atribuído pela VPN a carla.mendes desde 02:05:40Z." Cite também a consulta usada.

Exercício 19. (a) **Atraso de ingestão**: os eventos das 08h chegaram depois e foram contados às 09h; teste comparando event time e ingestion time. (b) **Lacuna seguida de reenvio em lote** (coletor parou e depois descarregou a fila); teste com o painel de saúde e os logs do coletor. Em ambos os casos, regras com janela curta podem ter perdido eventos.

Exercício 20. Porque o parser pode ter falhado e deixado o campo normalizado vazio ou com o valor errado, enquanto o texto original continua íntegro. Exemplo: após uma atualização, o firewall passa a mandar o IP de origem num campo novo; `src_ip` fica 0.0.0.0, mas o IP aparece no `raw`/`message`.

Exercício 12. Não, sozinha a proximidade não prova. A ligação fica forte se o **IP da resposta DNS** for o destino da conexão, o **cliente** for o mesmo host e, de preferência, o **processo** que consultou for o mesmo que conectou (Sysmon 22 e 3, EDR).

Gabaritos dos laboratórios

Lab 5.2

Item	Resposta
1	`2026-11-07T01:15:00Z` (virou o dia).
2	`2026-11-06T13:02:11Z` em UTC; `2026-11-06T10:02:11-03:00` em Brasília.
3	`2026-11-06T13:02:11Z` (premissas: ano 2026 e host em -03:00; registre-as).
4	`2026-11-06T23:21:05-03:00`.

Item	Resposta
5	Resposta pessoal. Em máquinas de domínio Windows, a fonte costuma ser um controlador de domínio; em casa, `time.windows.com` ou servidores NTP do sistema.

Lab 5.3

Linha	time_utc	src_ip	dst_ip	dst_port	user	action
1	2026-11-07T02:10:02Z	10.200.1.37	10.20.0.15	3389	n/d	allow
2	2026-11-07T02:05:40Z	n/d (*)	n/d	n/d	carla.mendes	success
3	2026-11-06T13:02:11Z	10.10.0.87	n/d (**)	443 (implícita)	ana.lima	allowed
4	2026-11-06T13:02:11.483Z	203.0.113.9	198.51.100.20	3389	n/d	block

(*) `assigned_ip` é o IP interno que a VPN entregou, não a origem; o IP público não está nesta linha. (**) A linha traz o domínio na URL, não o IP de destino.

Lab 5.4

1. Conversão para UTC. A VPN, o CSV do Windows e a aplicação já estão em UTC. O firewall está em -03:00: 23:10:02 local = **02:10:02Z**. A escala de plantão está em horário local: 22:00 a 02:00 (-03:00) = **01:00Z a 05:00Z**.

2. Fonte com relógio errado. O **SRV-RH01** está cerca de **660 segundos (11 minutos) adiantado**. Evidências: `w32tm /stripchart` mostra offset de -660,4 s em relação ao DC01 (o DC está atrás do servidor, logo o servidor está adiantado); `w32tm /query /status` mostra fonte "Local CMOS Clock", sem sincronização desde 10/10/2026. Conferência cruzada: o firewall registra o início do RDP às 02:10:02Z e o 4624 aparece às 02:21:05Z (diferença de 663 s, isto é, o drift mais cerca de 3 s de negociação do RDP); a sessão RDP no firewall dura 3096 s e termina às 03:01:38Z, enquanto o 4634 aparece às 03:12:40Z, que corrigido dá 03:01:39,6Z.

3. Timeline (UTC, com o SRV-RH01 corrigido em -660 s):

UTC	Fonte	Evento
02:03:51	VPN	Falha de senha para carla.mendes (1 tentativa), origem 203.0.113.45 (BR)
02:05:40	VPN	Login bem-sucedido, MFA aprovado na 1ª tentativa, dispositivo gerenciado NB-RH-007, IP atribuído 10.200.1.37
02:10:02	Firewall	RDP permitido de 10.200.1.37 para SRV-RH01 (10.20.0.15:3389), regra VPN-ADM-RH
02:10:04,6	SRV-RH01 (corrigido)	4624 tipo 10 de carla.mendes, origem 10.200.1.37, Logon ID 0x5A3F21; 4672 na mesma sessão
02:12:24	App da folha	Login de carla.mendes com origem SRV-RH01
02:12:58	App da folha	Fechamento da competência 2026-10 iniciado (lote F-2026-10-01)
02:58:31	App da folha	Fechamento concluído, 812 registros

UTC	Fonte	Evento
02:59:02	App da folha	Logout da aplicação
03:01:38	Firewall	Fim da sessão RDP (início + 3096 s)
03:01:39,6	SRV-RH01 (corrigido)	4634 logoff, Logon ID 0x5A3F21
03:02:10	VPN	Túnel encerrado (duração 3389 s)

Em horário local, o acesso foi de cerca de 23:05 a 00:02, dentro da janela de plantão (22:00 a 02:00) da mudança **CHG-2211**.

4. Duplicata. As duas primeiras linhas do CSV têm o mesmo **RecordId 884120** e campos idênticos, diferindo só em `CollectorId` (coletor-a e coletor-b). É o mesmo evento enviado por dois coletores. O firewall confirma uma única sessão RDP.

5. Classificação: Benigno Positivo. A regra acertou: houve RDP fora do horário comercial em servidor de RH. A atividade é legítima: plantão registrado com mudança aprovada (CHG-2211), acesso pela regra prevista para o grupo do RH, MFA aprovado na primeira tentativa, dispositivo gerenciado, e o log da aplicação mostra exatamente o fechamento da folha previsto. A falha de senha isolada às 02:03:51 é compatível com digitação errada. Não é falso positivo, porque a atividade detectada aconteceu.

6. Recomendações. (a) Abrir chamado para infraestrutura corrigir a sincronização de hora do SRV-RH01 (fonte "Local CMOS Clock"), anexando a evidência do desvio; enquanto isso, registrar o drift conhecido no handover. (b) Remover a duplicidade de coleta (dois coletores para a mesma fonte). Opcionais: avaliar exceção controlada da regra durante mudanças aprovadas do RH; fazer a regra usar o horário corrigido ou a hora do firewall.

Achado lateral (bônus): às 23:00:03 local (02:00:03Z), o firewall negou RDP de **10.200.1.21** (joao.pereira, TI, conforme a VPN) para o SRV-RH01, pela regra implícita. A política funcionou (o grupo de TI não tem essa permissão). Vale uma linha no ticket e, se o procedimento pedir, uma confirmação com o usuário sobre a tentativa.

Lab 5.5: saídas esperadas

```
# 1
2
# 2
2026-11-07T02:03:51Z event=auth_failure
2026-11-07T02:05:40Z event=auth_success
2026-11-07T02:05:41Z event=tunnel_up
2026-11-07T03:02:10Z event=tunnel_down
# 3   (duas linhas às 23:10:02: a sessão RDP usa TCP e UDP)
time=23:00:03   action="deny"    srcip=10.200.1.21
time=23:10:02   action="allow"   srcip=10.200.1.37
time=23:10:02   action="allow"   srcip=10.200.1.37
# 4
884120
# 5
2026-11-07T02:21:05.412Z 4624 carla.mendes 0x5A3F21
2026-11-07T02:21:05.412Z 4624 carla.mendes 0x5A3F21
2026-11-07T02:21:05.430Z 4672 carla.mendes 0x5A3F21
2026-11-07T03:12:40.008Z 4634 carla.mendes 0x5A3F21
# 6
"first_event_time": "2026-11-07T02:21:05Z"
# 7
2026-11-07T02:10:02Z
2026-11-07T02:10:05Z
```

```
# 8
action=login
action=fechamento_iniciado
action=fechamento_concluido
action=logout
```

Leitura: a 4 mostra a duplicata; a 5 mostra que todos os eventos do Windows pertencem à mesma sessão (Logon ID 0x5A3F21); a 6 mostra que o alerta usou o horário com drift; a 7 mostra que, corrigido, o logon fica 3 s depois da abertura da conexão no firewall.

Lab 5.6

1. Destinatários. Quatro, com o mesmo MessageId `<8812@mail.fatura-pagamentos.example>`, SPF e DMARC falhando: ana.lima, bruno.costa e carla.mendes (entregues na caixa) e diego.rocha (lixo eletrônico). Às 13:40:05Z as quatro cópias foram removidas pelo administrador.

2. Consulta e clique. O DNS mostra consultas a `fatura-pagamentos.example` de 10.10.0.87 (13:14:21Z) e 10.10.0.112 (13:20:05Z). O DHCP liga esses IPs a NB-FIN-042 (ana) e NB-FIN-051 (bruno). O proxy mostra que **ana** clicou às 10:14:22 local (13:14:22Z), com o acesso permitido (categoria "Newly Registered Domains"), e que **bruno** clicou às 10:20:06 local (13:20:06Z), já **bloqueado** (o domínio foi reclassificado como "Phishing").

3. Download e execução. Ana baixou `boleto_8812.zip` (412 KB) às 13:14:23Z. O EDR registra o ZIP em Downloads (13:14:24Z), a extração de `boleto_8812.exe` pelo Explorer (13:15:02Z) e a **detecção com quarentena** às 13:15:04Z, com `process_created: false`: o arquivo **não chegou a executar**. Sobre **carla**: não há consulta DNS nem acesso no proxy; o DHCP e o DNS mostram o notebook dela na rede do escritório nesse dia, apesar de a ficha dizer "home office às quintas". Isso sugere que ela não clicou pelo notebook na rede corporativa, mas não cobre celular ou outro dispositivo; confirme com ela. **diego**: mensagem no lixo eletrônico e nenhum registro de acesso.

UTC	Fonte	Evento
13:02:41 a 13:02:42	E-mail	Mensagem entregue a ana, bruno e carla; diego em lixo eletrônico
13:14:21,8	DNS	NB-FIN-042 (ana) resolve fatura-pagamentos.example
13:14:22	Proxy	ana acessa o link (permitido, 302)
13:14:23	Proxy	ana baixa boleto_8812.zip (permitido, 200)
13:14:24	EDR	ZIP gravado em Downloads de NB-FIN-042
13:15:02	EDR	boleto_8812.exe extraído pelo Explorer
13:15:04	EDR	Detecção, arquivo em quarentena, sem execução
13:20:05	DNS	NB-FIN-051 (bruno) resolve o domínio
13:20:06	Proxy	bruno acessa o link: bloqueado (403, Phishing)
13:40:05 a 13:40:06	E-mail	As quatro cópias removidas pelo administrador

5. Classificação: Verdadeiro Positivo. Phishing real, entregue, clicado, com download e tentativa de execução. O impacto parece contido (quarentena antes da execução, segundo clique bloqueado), mas

escalaria ao N2 conforme o Playbook de phishing/malware, porque houve artefato no endpoint e é preciso confirmar que nada mais aconteceu.

6. Ações. Já feitas: remoção das mensagens (13:40Z), reclassificação/bloqueio do domínio no proxy (antes de 13:20Z), quarentena do arquivo pelo EDR. Faltam: bloquear o domínio e os IPs também no DNS e no firewall; buscar o hash e o domínio em todo o ambiente; verificar NB-FIN-042 (varredura completa e conexões após 13:15Z); confirmar com ana se digitou alguma informação (não há POST no proxy); confirmar com carla; registrar os indicadores; orientar os destinatários.

Lab 5.7

Problema	Evidência	Impacto
Duplicata	Linhas 2 e 3 idênticas (só muda o número da linha).	Contagens infladas; regras de volume podem disparar ou contar errado.
Lacuna	Nenhum evento entre 01:12:03 e 03:47:12; painel com 208 (01h), 0 (02h) e 96 (03h) contra cerca de 1.200 por hora.	Cerca de 2h35 sem visibilidade; nada pode ser afirmado sobre esse período.
Parser quebrado	A partir da linha 5: `src_ip` = 0.0.0.0, `src_port` = 0 e o IP de origem aparece no campo `user`.	Regras e buscas por IP de origem ficam cegas.
Linha truncada	Linha 6 com 7 campos (faltam porta, ação e usuário).	Evento incompleto; não dá para saber se foi permitido.
Atraso de ingestão	Linhas 9 e 10 com cerca de 41 min de atraso (2.498 s e 2.503 s); painel com 0 às 08h e 2.710 às 09h.	Regras de janela curta perdem eventos; o painel engana.
Comunicação	`mudancas.txt`: CHG-2230 sem comunicado ao SOC.	Ninguém sabia que a fonte ia parar.

Achado escondido: na linha 8 (05:10:09), com o parser quebrado, o IP de origem real está no campo `user`: **10.10.0.91** fez uma conexão **permitida** para 203.0.113.66 na porta **8443**. Uma estação falando com porta incomum na internet, de madrugada, que nenhuma regra viu porque o `src_ip` estava zerado. Isso precisa de investigação. A linha 7 também mostra que 203.0.113.200 (o mesmo IP da varredura RDP da linha 2) continuou tentando a porta 3389 (negado).

Resposta ao gestor: "Não dá para afirmar que a madrugada foi tranquila. De 01:12 a 03:47 o firewall não enviou eventos (atualização CHG-2230) e, depois disso, o campo de origem chegou quebrado, o que deixou regras sem funcionar. Revisando manualmente, encontrei uma conexão de 10.10.0.91 para um IP externo na porta 8443 às 05:10, que estou investigando. Nos dados disponíveis, não há outros sinais."

Quem acionar: SIEM Engineer (corrigir parser, remover duplicidade, verificar atraso de ingestão); equipe de redes (confirmar o reboot e se o firewall guardou log local do período); N2/Lead (investigar 10.10.0.91); gestão de mudanças (incluir o SOC no comunicado de mudanças que afetam fontes de log).

Próximo módulo

Módulo 6: SIEM. Ingestão, coletores, agentes, syslog e APIs; parsing, normalização, correlação e enriquecimento; retenção, EPS e volume; regras, casos, dashboards e alertas; e consultas básicas em KQL,

SPL e Lucene/OpenSearch para buscar IP, usuário, hostname, hash, processo, domínio, URL, login, RDP e SMB.